What We Know about AIBOMs: Results from a Multivocal Literature Review on Artificial Intelligence Bill of Materials

SABATO NOCERA, University of Salerno, Italy
MASSIMILIANO DI PENTA, University of Sannio, Italy
FATIMA AHMED, University of Salerno, Italy
SIMONE ROMANO, University of Salerno, Italy
GIUSEPPE SCANNIELLO, University of Salerno, Italy

The increasing adoption of Artificial Intelligence (AI) in software systems has raised concerns regarding transparency, accountability, and security in the AI supply chain. To address these challenges, Artificial Intelligence Bills of Materials (AIBOMs) have emerged as structured artifacts documenting AI components, datasets, tools, and methodologies used in AI-enabled systems. This paper presents the results of a Multivocal Literature Review (MLR) on AIBOMs. An MLR systematically maps existing evidence while synthesizing key findings from formal literature (FL) and gray literature (GL) to understand emerging themes in evolving fields. Our MLR synthesizes insights from FL and GL to understand benefits, regulatory implications, structural elements, applications, and challenges behind the use of AIBOMs. Our work aims to inform practitioners and researchers about the state of AIBOMs and their role in fostering responsible AI use and deployment. The results of our MLR suggest that AIBOMs improve quality, traceability, management, and compliance in AI-enabled systems by documenting models, datasets, and their relationships. However, several challenges remain to be addressed, including immature generation and consumption tools, data source availability, poor interoperability with existing infrastructures, and limited stakeholder awareness.

CCS Concepts: • **Software and its engineering**; • **Computing methodologies → Artificial intelligence**; • **Applied computing → Supply chain management**;

Additional Key Words and Phrases: Software Bill of Materials, Artificial Intelligence Bill of Materials, Machine Learning Bill of Materials, Multivocal Literature Review

1 Introduction

The integration of Artificial Intelligence (AI) into software systems has become ubiquitous across various domains, such as healthcare, finance, and autonomous vehicles [83]. While AI promises numerous benefits, it introduces new complexities regarding transparency, security, and compliance within the software supply chain.

In the context of conventional software systems, Software Bills of Materials (SBOMs) [90] have been promoted as a mechanism for documenting and tracking the components and dependencies of software systems, and helping organizations manage security risks and compliance requirements [8, 10, 75, 88, 96].

The concept of an AI Bill of Materials (AIBOM) [11] has been introduced to address similar challenges in AI-enabled systems. An AIBOM is a structured inventory, detailing AI models, datasets, training processes,

Authors' addresses: Sabato Nocera, University of Salerno, Fisciano, Italy, snocera@unisa.it; Massimiliano Di Penta, University of Sannio, Benevento, Italy, dipenta@unisannio.it; Fatima Ahmed, University of Salerno, Fisciano, Italy, fahmed@unisa.it; Simone Romano, University of Salerno, Fisciano, Italy, siromano@unisa.it; Giuseppe Scanniello, University of Salerno, Fisciano, Italy, gscanniello@unisa.it.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
© 2025 Copyright held by the owner/author(s).
ACM 1557-7392/2025/12-ART
https://doi.org/10.1145/3786773

Just Accepted

hardware dependencies, and software libraries involved in developing and deploying AI-enabled systems. Such an inventory improves traceability, accountability, and regulatory compliance, particularly in sectors requiring strict adherence to legal frameworks.

Despite the growing interest in AIBOMs from academia and industry, there is a gap between theory and practice, with research emerging from both formal academic sources and gray literature (*e.g.,* technical blogs, industry white papers, and online discussions). Given the rapid evolution and the increased use of AI solutions and the practical challenges of implementing AIBOMs, a structured synthesis of available knowledge is necessary to give researchers the contextual depth they need for relevant research and offer to practitioners validated and comprehensive guidance grounded in both academic and experiential knowledge. In this respect, a Multivocal Literature Review (MLR) [57] is a valuable tool because it represents a systematic approach to aggregating insights from both formal literature (FL) and gray literature (GL), ensuring a more comprehensive, practical, and balanced understanding of a topic. Unlike traditional Systematic Literature Reviews (SLRs) [68], which focus primarily on peer-reviewed academic research, MLRs explicitly incorporate practitioner knowledge from sources as technical blogs, reports from regulatory bodies, and industry white papers. In other words, conducting an MLR on AIBOMs is highly relevant and necessary because of: *(i)* the novelty of the topic (AIBOMs are an emerging technology and there is a lack of consolidated academic research on their implementation and impact); *(ii)* regulatory push (*e.g.,* the EU AI Act [51] and policies such as the NIST AI Risk Managerment framework [32, 73]); *(iii)* industry adoption (*e.g.,* large tech companies and government agencies—including the US Army and cybersecurity firms—are exploring AIBOMs as a mechanism to secure AI-enabled systems); and *(iv)* interdisciplinary perspectives (AIBOMs intersect multiple research fields, including software engineering, AI ethics, cybersecurity, and legal studies, necessitating a multivocal review approach).

In this paper, we present the results of an MLR, with the primary objective of investigating:

> The state of practice and research concerning the adoption, structure, use, and challenges of Artificial Intelligence Bills of Materials (AIBOMs).

Therefore, the overarching goal of our research is to provide a comprehensive perspective on the current state of AIBOMs and their potential role in deploying AI-enabled systems by contributing to advancing AI governance, software supply chain security, and responsible AI deployment.

The results of our MLR suggest that AIBOMs can significantly improve quality, traceability, management, and compliance in AI-enabled systems by documenting models, datasets, and their relationships. However, several challenges remain to be addressed—each representing an opportunity for advancement—including immature generation and consumption tools, data source availability, poor interoperability with existing infrastructures, and limited stakeholder awareness.

While these findings carry important implications for several stakeholders, the primary target audience of our MLR is practitioners and researchers. Practitioners are encouraged to adopt AIBOMs for managing risks, ensuring compliance, enhancing accountability, and operationalizing responsible AI practices. Researchers, in turn, should assess the practical impact of AIBOMs and advance methods for their automated generation and consumption to support transparency, ethical practices, and traceability in AI-enabled systems.

The rest of the paper is organized as follows. Section 2 presents background information and research related to ours. Section 3 details the design of our MLR, including research questions (RQs), search strategy, and data collection methodologies. Section 4 presents the results, discussing identified themes related to AIBOMs from both formal and gray literature. Section 5 provides an overall discussion of the results, presents the key practical implications for our MLR, and highlights possible threats to validity. We conclude the paper, underlining key contributions and future research directions, in Section 6.

Just Accepted

2 Background and Related Work

A software supply chain encompasses all components and processes involved in the development and delivery of a software product. As governmental regulations enforce software supply chain management (*e.g.,* [52, 91]), SBOMs are becoming relevant and crucial. An SBOM lists the inventory of components used in building a given software product, often composed of open-source and proprietary components [90]. When the list includes AI components, we refer to it as an AIBOM [11] (also known as ML-BOMs or DataBOMs [8]). In other words, AIBOMs are specialized SBOMs in the sense that SBOMs describing AI components can be referred to as AIBOMs. To some extent, the concept of AIBOM has been introduced to address challenges similar to those addressed by SBOMs, but for AI-enabled systems. The use of AIBOMs could also extend to specific AI application contexts, such as the supply chains of large language models (LLMs) [64]. In this scenario, new regulatory frameworks are emerging to govern the use of AI. For example, the EU AI Act [51] mandates products with embedded AI to be assessed based on risk levels throughout their lifecycle, with stringent requirements for high-risk applications to ensure transparency, accountability, and compliance with laws.

The definitions of SBOM and AIBOM alone do not provide guidance on what these component lists should contain. For SBOMs, the US Department of Commerce has outlined minimum and recommended data fields [76, 90]. The minimum fields include essential information such as the component name, version, supplier, unique identifiers, dependency relationships, the author of the SBOM data, and the timestamp of SBOM generation. The recommended fields include the component hashes, life cycle phase, additional component relationships, and licenses. Guidance specific for AI components is absent, leaving the content of AIBOMs unclear. However, this guidance is crucial because AI-enabled systems—which integrate data and components that implement algorithms designed to mimic human learning and problem-solving [78]—exhibit fundamentally different characteristics compared to traditional software. Their behavior is significantly influenced by AI, including Machine Learning (ML) models [78]. Additionally, the development of AI-enabled systems differs from traditional software, with the process often fragmented in ways that can obscure and diffuse ethical responsibility across multiple stakeholders [93].

Even when guidance is available on the elements that SBOMs/AIBOMs should contain for each listed component, representing these elements—and, by extension, the entire SBOM/AIBOM—requires a standardized schema to ensure machine-readability. An SBOM standard is a machine-readable schema, typically formalized in JSON or XML, designed to provide a uniform structure for describing the composition of SBOMs, enabling these to be processed by other tools (*e.g.,* vulnerability or license scanners). The most widely adopted standards are SPDX and CycloneDX [10, 76]. Traditional SBOM standards need adaptation to represent AI components and, by extension, AIBOMs. For example, CycloneDX introduced fields to track AI components and their associated metadata starting with version 1.5 in 2023, while SPDX began offering similar support in version 3.0, with a beta released in June 2024.

Some primary studies have explored SBOMs, while only recently has the body of literature on AIBOMs been expanding. However, this body remains highly fragmented and shows a gap between theory and practice, with research emerging from both formal academic sources and gray literature, *e.g.,* technical blogs, industry white papers, and online discussions. For example, scholarly works often emphasize theoretical models or conceptual frameworks, whereas industry contributions frequently lack methodological rigor and validation. As a result, synthesizing knowledge across these domains presents significant challenges. This tension underscores a critical need to bridge academic inquiry with real-world application and suggests secondary studies to analyze and synthesize existing research on AIBOMs systematically. To a large extent, this gap in the literature motivates our MLR, which aims to provide a structured overview of the existing state of the art and practice, thereby informing and guiding future work in the field.

Just Accepted

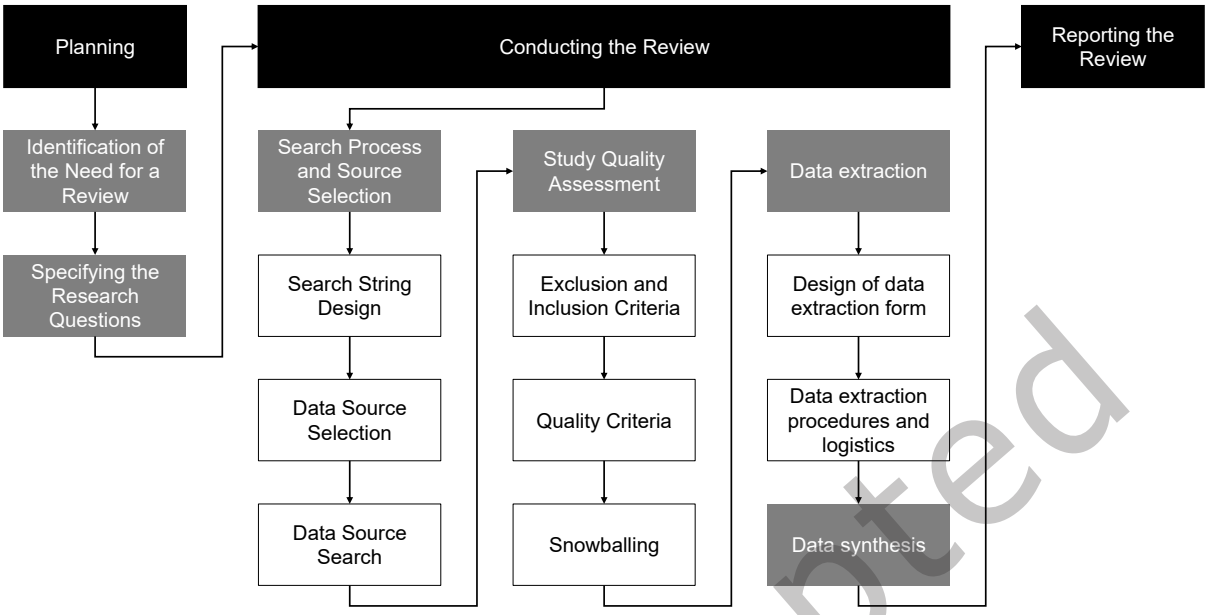

Fig. 1. Overview of the phases/steps of the Multivocal Literature Review.

Just Accepted

3 Study Design

In this section, we describe the study design following the guidelines for including GL and conducting MLRs in SE by Garousi *et al.* [57]. These are based on the guidelines for performing SLRs in SE by Kitchenham and Charters [68] and Kitchenham *et al.* [67]. An overview of the steps conducted to perform the MLR is shown in Figure 1.

3.1 Planning

In the following, we present the planning phase of the MLR, which includes establishing the need for an MLR on AIBOMs and defining its goal and RQs.

3.1.1 Identification of the Need for a Review. Before planning/executing the MLR, we performed an extensive search to ensure that a systematic review about AIBOMs was necessary. To this end, we queried Google Scholar to identify any existing secondary studies on the topic by using the following search string:

```
( ``artificial intelligence BOM'' OR ``ai BOM'' OR ``artificial intelligence bill of
materials'' OR ``ai bill of materials'' OR ``AIBOM'' OR ``AI-BOM'' OR ``machine
learning BOM'' OR ``ml BOM'' OR ``machine learning bill of materials'' OR ``ml
bill of materials'' OR ``MLBOM'' OR ``ML-BOM'' OR ``data BOM'' OR ``data bill of
materials'' OR ``DataBOM'' OR ``Data-BOM'' ) AND ( ``review'' )
```

Our search procedure, inspired by common practices in exploratory literature reviews, entailed reviewing the first ten pages of results [62]. We monitored for diminishing returns, and, upon reaching the tenth page without identifying any additional pertinent contributions, we concluded the search. Over the analyzed results, we found no review about AIBOMs from either FL or GL. This outcome justifies the systematic review on AIBOM presented in this paper.

Table 1. Items to decide whether to include the gray literature in software engineering reviews [57].

#	Item	Response
1	Is the subject "complex" and not solvable by considering only the formal literature?	Yes
2	Is there a lack of volume or quality of evidence, or a lack of consensus on outcome measurement in the formal literature?	Yes
3	Is the contextual information important to the subject under study?	Yes
4	Is it the goal to validate or corroborate scientific outcomes with practical experiences?	Yes
5	Is it the goal to challenge assumptions or falsify results from practice using academic research or vice versa?	Yes
6	Would a synthesis of insights and evidence from the industrial and academic community be useful to one or even both communities?	Yes
7	Is there a large volume of practitioner sources indicating high practitioner interest in a topic?	Yes

The choice of including GL and, therefore, conducting an MLR was made systematically using a well-defined checklist provided by Garousi *et al.* [57]. We report such a checklist, along with the responses, in Table 1. Each response can be either "yes" or "no": one or more "yes" responses justify the inclusion of GL in the systematic review and then the execution of an MLR. Below, we motivate our response, *i.e.,* "yes" response, to all the items shown in such a table.

#1. AIBOM is a rather novel topic, as well as "complex", since it captures various and interconnected aspects of SE and AI (*e.g.,* ML-enabled software systems). Moreover, these aspects can be approached from different perspectives (*e.g.,* practice and research).

#2. FL about AIBOMs is scarce, probably due to the topic's novelty. We acknowledged a lack of FL about AIBOMs while searching for prior systematic reviews. Nevertheless, such a novelty further motivates the need to investigate "current" perspectives about AIBOMs emerging from GL.

#3. Contextual information, which includes the approaches enabling a given technology [46, 49, 81, 82], is crucial to investigate AIBOM. Indeed, this topic has a high relevance for practitioners who need to manage the AI supply chain of their software products, complying with regulations such as the EU AI Act [51] or US Executive Order on Improving the Nation's Cybersecurity [89]. AIBOMs are also important for developers who use AI in their software to improve transparency about the components, data sources, and models used in AI-enabled systems and help them understand what they rely on. That is, consumers of AIBOMs are empowered to make informed decisions, build trust, and evaluate potential risks, biases, and ethical concerns associated with the AI solution.

#4. We seek to corroborate formal research on AIBOMs with insights provided by the practice. GL in the systematic review would lead to findings useful for researchers and practitioners.

#5. The investigation of FL and GL could shed light on and question common beliefs about AIBOMs. This investigation would provide researchers and practitioners with more reliable knowledge about AIBOMs.

#6. Reliable knowledge about AIBOMs, emerging from an analysis of both FL and GL, would be useful to researchers and practitioners.

#7. We found a large volume of evidence indicating high interest in AIBOM by practitioners.

3.1.2 Specifying the Research Questions. Following the guidelines by Garousi *et al.* [57], we leveraged the Goal-Question-Metric (GQM) methodology [44] to formalize the goal and RQs of our MLR. Specifically, the *goal* was to analyze FL and GL about AIBOMs *for the purpose of* improving their understanding *with respect to (i)*

Just Accepted

motivations/benefits, *(ii)* laws/regulations, *(iii)* elements, *(iv)* use cases, *(v)* approaches/tool categories/techniques, and *(vi)* limitations/challenges. The *perspective* is that of practitioners and researchers. The *context* consists of research papers retrieved from specialized databases and digital libraries (for the FL) and resources retrieved from general web search engines (for the GL).

Based on the goal mentioned above and the classification scheme proposed by Easterbrook *et al.* [50], we formulated six *exploratory* RQs of type *descriptive-classification*, which are appropriate when attempting to understand a given topic. We describe these RQs below.

RQ1. What are the motivations and benefits of using AIBOMs?
This RQ aims to study the motivations and benefits of using AIBOMs. Understanding these motivations and benefits—even those that might be deemed clear or self-evident—is essential to assessing the value proposition of AIBOMs in practical settings. Answering this RQ sheds light on the impact that AIBOMs could have for practitioners. Indeed, the findings of this RQ are expected to provide practitioners and researchers with insights into the drivers and practical advantages of integrating AIBOMs into software development.

RQ2. What are the laws and regulations related to using AIBOMs?
Practitioners (e.g., developers) need to comply with regulations when developing and distributing software [75]. As AI-enabled systems become increasingly pervasive, practitioners must navigate a growing body of regulations related, for example, to transparency, accountability, data provenance, and ethical AI. RQ2 seeks to identify which laws, standards, and compliance requirements can be addressed or supported by adopting AIBOMs. By examining these aspects, we aim to understand the role AIBOMs can play in helping organizations meet their regulatory obligations and reduce the risk of non-compliance throughout the AI software lifecycle.

RQ3. What elements are included or worth including in AIBOMs?
This RQ investigates the essential elements that constitute an AIBOM. As a structured artifact, an AIBOM is expected to capture comprehensive information about the AI-enabled system it documents—including, but not limited to, machine learning models, training and test datasets, software dependencies, configuration parameters, and metadata related to performance, fairness, and provenance. Through RQ3, we aim to identify which elements are currently included in existing AIBOMs, and to propose additional elements that may be worth including. Answering this RQ would offer guidance on the data fields that should constitute AIBOMs and their differences with the data fields suggested by NTIA [90] for traditional SBOMs, as described in Section 2. The findings would drive the design of AIBOM standards and the development of tools for AIBOM automated generation and validation. That is, the study of this RQ is relevant for both researchers and practitioners.

RQ4. What are the use cases where AIBOMs are used?
This RQ aims to study the use cases associated with AIBOMs consumption. That is, we want to understand what activities related to the development and management of software products could be supported using AIBOMs. This sheds light on best practices that practitioners could adopt to exploit AIBOMs effectively and efficiently.

RQ5. What are the approaches, tool categories, and techniques to deal with AIBOMs?
This RQ aims to unveil the approaches, tool categories, and techniques to deal with AIBOMs. That is, we want to understand the approaches used by practitioners to produce and consume AIBOMs, as well as the tools that could be employed to this end.

RQ6. What are the limitations and challenges of AIBOMs?
The need to manage the AI supply chain of software products has been growing in the past few years, and AIBOM provides a way to support this. However, the adoption of AIBOMs could be hindered by limitations and challenges associated with such a novel technology. This RQ aims to unveil such limitations and challenges associated with AIBOM, along with possible solutions.

Just Accepted

3.2 Conducting the Review

In the following, we present the conduction phase of the MLR, which includes the search process and source selection, study quality assessment, data extraction, and data synthesis.

3.2.1 Search Process and Source Selection. The search process and source selection involve designing the search string, selecting the data sources, and conducting the searches within those sources.

Search String Design. We constructed a search string to retrieve both FL and GL, guided by the key terms derived from the RQs and supplemented by relevant synonyms and alternative expressions. An iterative refinement process was employed to obtain the final search string—*e.g.,* evaluating the top results for relevance to assess how well the search string meets our RQs, and balancing breadth and specificity of the search string to enhance coverage and relevance—during which it was progressively adjusted to reach the final used version. The final search string used is the following:

```
( ``artificial intelligence BOM'' OR ``ai BOM'' OR ``artificial intelligence bill of
materials'' OR ``ai bill of materials'' OR ``AIBOM'' OR ``AI-BOM'' OR ``machine
learning BOM'' OR ``ml BOM'' OR ``machine learning bill of materials'' OR ``ml
bill of materials'' OR ``MLBOM'' OR ``ML-BOM'' OR ``data BOM'' OR ``data bill of
materials'' OR ``DataBOM'' OR ``Data-BOM'' ) AND ( ``motivation*'' OR ``benefit*''
OR ``law*'' OR ``regulation*'' OR ``element*'' OR ``dataset*'' OR ``model*'' OR
``data field*'' OR ``use case*'' OR ``approach*'' OR ``tool*'' OR ``technique*'' OR
``limitation*''
OR ``challeng*'' )
```

Data Source Selection. Below, we present the data sources chosen to search for FL and GL:

FL. We used the following three data sources: Scopus [84], IEEE Xplore [65], and ACM Digital Library [41]. Scopus is a broad-coverage abstract database, while IEEE Xplore and ACM Digital Library are full-text databases with more limited coverage. These three are considered among the top computer science FL data sources [79], have been used in many other literature reviews [54, 59, 66, 67], and are recommended by the guidelines [57, 68].

GL. We leveraged the Google search engine [61]. It is a general web search engine that has been used by other MLRs [42, 71], including in the field of SE [54, 59, 66]. The Google search engine is also recommended by the guidelines for including GL in systematic reviews [43, 57].

We planned to collect all the literature resulting from the search on Scopus, IEEE Xplore, and ACM Digital Library. However, as for the GL, this could not be accomplished due to the large number of results that the Google search would have produced [57, 77]. Therefore, we had to decide *data exhaustion stopping criteria* [57] for the GL search. We followed the suggestions by Garousi *et al.* [57, 59] and employed an *effort bounded* stopping criterion augmented with an *evidence exhaustion* stopping criterion. Therefore, we first analyzed a limited number of pages produced by the Google search (effort-bound). We chose to analyze the first ten pages of results because this threshold has been used by other authors [69, 70]. We continued the search further if the results of the last page still provided additional evidence (evidence exhaustion). Note that the effort-bound criterion was applied to prevent the impractical task of reviewing hundreds/thousands of Google search results. Nonetheless, in accordance with our evidence exhaustion criterion, we would have continued exploring beyond the initial ten pages whenever potentially relevant sources appeared. In practice, we observed diminishing returns after the first few pages, with a substantial drop in relevance; by the tenth page, no additional valuable sources were identified.

Data Source Search. Figure 2 illustrates the source selection process, including the search conducted across the selected data sources. We queried the data sources on February 3, 2025. The search string was applied to the

Just Accepted

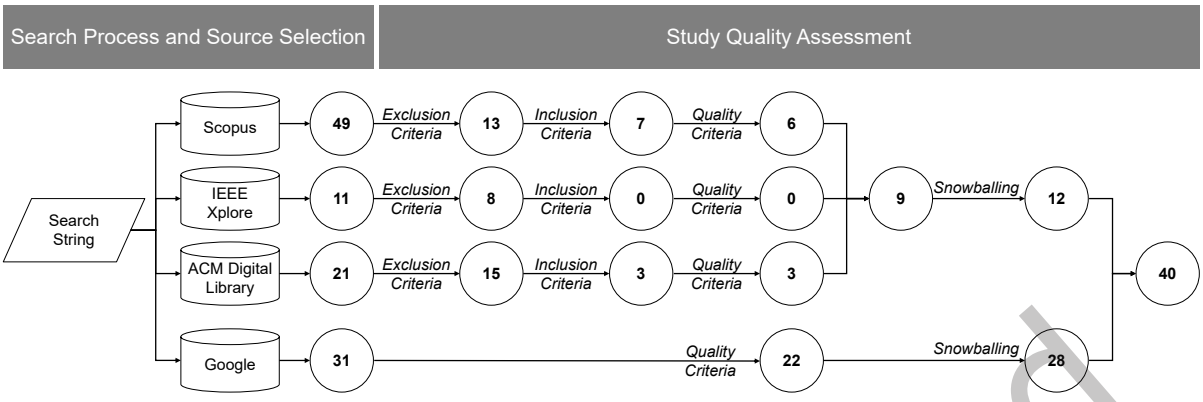

Fig. 2. Source selection process.

Table 2. Exclusion, inclusion, and quality criteria for FL.

Exclusion Criteria	Inclusion Criteria	Quality Criteria
EC1 - The paper is not written in English EC2 - The paper is not in the field of software engineering or computer science EC3 - The paper is a secondary study EC4 - The paper is a duplicate	IC1 - The paper deals with (Software) Bill of Materials for artificial intelligence IC2 - The paper has the full text available	Q1 - The paper clearly reports valuable information for the review Q2 - The paper clearly reports its RQs and/or objectives Q3 - The paper clearly reports the results/findings

full text of the sources. As for FL, we retrieved a total of 81 papers: 49 from Scopus, 11 from IEEE Xplore, and 21 from the ACM Digital Library. As for the GL, our Google search returned over 250,000 results. Following the defined stopping criteria, we reviewed the first ten pages of results and identified 31 relevant sources.

3.2.2 Study Quality Assessment. Once the potentially relevant primary sources were collected, we assessed their relevance. This involved defining detailed selection criteria and then systematically applying them (see Figure 2). We distinguished the following three types of selection criteria:

- *Exclusion Criteria*. They are applied only to the title, abstract, and keywords. The source is excluded if any of the criteria are met.
- *Inclusion Criteria*. They are applied only to a given source's full text. The source is included if all criteria are met.
- *Quality Criteria*. They are applied only to a given source's full text. These criteria are used to evaluate the quality of the sources. The source is included if deemed of enough quality, *i.e.,* its evaluation meets or exceeds a certain threshold.

Following the guidelines for including GL and conducting MLRs in SE by Garousi *et al.* [57], we applied distinct criteria for FL and GL sources. In particular, we applied only quality criteria to the GL sources, which were distinct from those used for FL. This is because, in the case of GL, inclusion and exclusion criteria often overlap with, and are sometimes integrated into, quality criteria [57].

Just Accepted

Table 3. Quality assessment checklist of gray literature for software engineering [57].

Criteria	Question	
Authority of the producer	QGL1	Is the publishing organization reputable? *e.g.,* the Software Engineering Institute (SEI)
	QGL2	Is an individual author associated with a reputable organization?
	QGL3	Has the author published other work in the field?
	QGL4	Does the author have expertise in the area? (*e.g.,* job title principal software engineer)
Methodology	QGL5	Does the source have a clearly stated aim?
	QGL6	Does the source have a stated methodology?
	QGL7	Is the source supported by authoritative, contemporary references?
	QGL8	Are any limits clearly stated?
	QGL9	Does the work cover a specific question?
	QGL10	Does the work refer to a particular population or case?
Objectivity	QGL11	Does the work seem to be balanced in presentation?
	QGL12	Is the statement in the sources as objective as possible? Or, is the statement a subjective opinion?
	QGL13	Is there a vested interest? *e.g.,* a tool comparison by authors that are working for a particular tool vendor
	QGL14	Are the conclusions supported by the data?
Date	QGL15	Does the item have a clearly stated date?
Position w.r.t. related sources	QGL16	Have key related GL or formal sources been linked to / discussed?
Novelty	QGL17	Does it enrich or add something unique to the research?
	QGL18	Does it strengthen or refute a current position?
Outlet type	QGL19	• 1st tier GL (measure=1): High outlet control/ High credibility: Books, magazines, theses, government reports, white papers • 2nd tier GL (measure=0.5): Moderate outlet control/ Moderate credibility: Annual reports, news articles, presentations, videos, Q/A sites (such as StackOverflow), Wiki articles • 3rd tier GL (measure=0): Low outlet control/ Low credibility: Blogs, emails, tweets

Just Accepted

Exclusion and Inclusion Criteria. Table 2 shows the exclusion and inclusion criteria for including the FL. Each criterion was evaluated as either *True* or *False*. Applying these criteria allowed us to include only sources related to the topic of interest, namely AIBOMs. It is worth mentioning that BOMs have been extensively used and studied in other fields, such as manufacturing, so we had to ensure that the selected sources explored the use of BOMs for AI. The application of the exclusion criteria reduced the initial set of 81 papers to 36, and the subsequent application of the inclusion criteria further narrowed this down to nine scientific papers (*i.e.,* FL sources).

Quality Criteria. Table 2 shows the quality criteria applied to the FL sources. In line with established guidelines [57, 67, 68], each quality criterion could be answered using a 3-point Likert scale (yes = 1, partly = 0.5, and no = 0). The sum of these values reflects the quality score for a given source. Then, we defined the minimum

acceptable quality score as the maximum possible quality score divided by two [57]. We excluded the FL sources whose quality score was lower than 1.5 (3/2). Applying the quality criteria resulted in discarding only one paper, leading to the inclusion of nine papers for the FL in the MLR.

Table 3 shows the quality criteria applied to the GL sources. These criteria were not arbitrarily defined but were adopted directly from the established guidelines by Garousi *et al.* [57]. Each criterion was associated with one or more questions, and each question could be answered according to a 3-point Likert scale (yes = 1, partly = 0.5, and no = 0) [57, 67, 68]. We excluded the GL sources whose quality score was lower than 9.5 (19/2) [57]. The application of the quality criteria resulted in discarding nine sources, leading to the selection of 22 sources for the GL.

We imported the FL sources into one spreadsheet and the GL sources into another spreadsheet. Each spreadsheet reported the criteria for the corresponding sources, *i.e.,* FL or GL. Two authors of this paper applied separately the exclusion, inclusion, and quality criteria for each source. In case of disagreement, the final decision on including a given source was made through a discussion between the two authors who applied the inclusion, exclusion, and quality criteria. If consensus could not be reached, the plan was to involve the remaining authors. This was not necessary, as all disagreements were always resolved. It is worth mentioning that we calculated the Cohen's κ coefficient to evaluate authors' agreement (see Section 5.2).

Snowballing. After applying the inclusion, exclusion, and quality criteria to the initial set of sources, we performed snowballing following Wohlin's guidelines [94] for systematic literature studies. Snowballing involves using reference lists (backward snowballing) and citation lists (forward snowballing) to identify additional relevant papers. This process helped mitigate the risk of omitting important literature from this MLR [94].

We applied snowballing to the FL sources that passed the inclusion and exclusion criteria, and to the GL sources that passed the quality criteria. Each source identified through snowballing was evaluated using the same criteria previously defined for FL and GL (depending on whether it belonged to FL or GL). We performed backward and forward snowballing iteratively until no new sources were found in the reference or citation lists—thus, we repeated the process multiple times for both FL and GL.

For backward snowballing of FL sources, we examined the reference lists of the selected papers; for forward snowballing, we used Google Scholar to identify citing sources. Regarding GL sources, following the guidelines by Garousi *et al.* [57], we performed backward snowballing by extracting links and references from each source through *Link Gopher*[1], *Extract Link PDF*[2], and *Link Grabber*[3]; to identify forward links to GL sources, we used *Ahrefs Link Grabber*[4], a web-based service that tracks backlinks.

Through snowballing, we identified three additional papers for the FL and six additional sources for the GL. As a result, our final selection comprised 12 FL papers and 28 GL sources, totaling 40 sources used for data extraction and synthesis.

3.2.3 Data extraction. For the data extraction phase, we present the design of the data extraction form and the procedures and logistics used for data extraction.

Design of data extraction form. In designing the data extraction form, we ensured traceability to the RQs of the MLR. This approach was necessary to identify relevant elements for addressing each RQ. We systematically mapped each RQ to specific attributes or aspects to clarify the data to be extracted. For example, in the case of RQ1 (What are the motivations and benefits of using AIBOMs?), we identified "motivations" and "benefits" as key aspects. The data extraction form was defined through brainstorming and discussion among all authors. In

[1]https://chromewebstore.google.com/detail/bpjdkodgnbfalgghnbeggfbfjpcfamkf?utm_source=item-share-cb
[2]https://chromewebstore.google.com/detail/fchghbfimckdiapkacfaljimmkojgfhi?utm_source=item-share-cb
[3]https://chromewebstore.google.com/detail/caodelkhipncidmoebgbbeemedohcdma?utm_source=item-share-cb
[4]https://ahrefs.com/backlink-checker

Just Accepted

addition to RQ-specific data, we also extracted more generic data, such as publication year, contribution type, and research type, as recommended by existing guidelines [57, 68]. Similar to other authors [54, 59, 66], we conducted a pilot data extraction on a random sample of sources to validate and refine the data extraction form.

Data extraction procedures and logistics. We imported all the sources into two spreadsheets hosted on Google Docs, one for each author involved in the data extraction. We added a new column for each field in the data extraction form. This structure ensured explicit traceability links between the sources and the extracted data. Two authors independently extracted data from the sources in random order, recording all information necessary to answer each RQ. In cases where different pieces of information were extracted for a given source, a discussion was planned between the two authors to deal with this discrepancy. This collaborative process helped ensure the quality and validity of the extracted data, in line with established guidelines for literature reviews [57]. All extracted data are available in our online supplementary material [74].

3.2.4 Data synthesis. During the data synthesis phase, the first author synthesized the previously extracted data using qualitative coding techniques [72], specifically applying open coding followed by axial coding. This approach is considered to be particularly appropriate for the data synthesis of GL sources, which often contain rich narrative content suitable for qualitative synthesis [57]. In cases where the first author was uncertain about how to synthesize the data extracted from a source, the plan was to consult the other authors for support. However, such situations did not occur.

In the open coding phase, we systematically examined the extracted data for each field in the data extraction form and assigned descriptive codes that captured the underlying concepts. Whenever a new concept emerged (*i.e.,* it was not yet represented by an existing code), we created a new code and added a corresponding column to the spreadsheet. We then placed the relevant data segment into that column. For example, during the synthesis of data for RQ1 (What are the motivations and benefits of using AIBOMs?), we examined the entries under the "Motivations / Benefits" column in the data extraction form. From the source [GL33], we synthesized the following extracted data:

> *As the adoption of artificial intelligence (AI) and machine learning (ML) systems becomes more widespread, the need for transparency, and traceability in AI development has never been more crucial. [...] Transparency and Trust: AI BOMs ensure that every element used in an AI solution is documented. This transparency fosters trust among users, developers, and stakeholders. [...] AI BOMs are set to play a pivotal role in ensuring that AI models are developed and deployed responsibly. [...] With AI becoming an integral part of our lives and potential regulations in the horizons, AI BOMs are set to play a pivotal role in ensuring that AI models are developed and deployed responsibly.*

Several new concepts emerged from this extracted data: "Transparency," "Traceability," "Trust," "Responsibility," and "Regulatory Compliance." For each of these emerging concepts, a new column in the spreadsheet was created, treating each concept as a distinct code. Then, each new entry was populated with the relevant data segments from the source [GL33]. If a concept had already been coded previously, the new data segment was added to the existing column for that code. This process was iterative, involving constant comparison and refinement of codes to ensure they accurately reflected the meaning of the data. We aimed to strike a balance between granularity and abstraction, following best practices for qualitative analysis [72]. For instance, as documented in the replication package [74], the first iteration of data synthesis identified "Innovation" as a motivation/benefit (RQ1) based on a single source (*i.e.,* [GL32]). However, in subsequent iterations, this code was removed as the supporting evidence was deemed non-substantive and lacked analytical depth, making it insufficient to justify inclusion.

Lastly, we conducted axial coding [86, 92], which was necessary to group codes identified during the open coding process into higher-level categories/themes [57]. For example, the codes "Transparency," "Traceability," "Trust," "Responsibility," "Regulatory," and "Compliance" (identified in response to RQ1) were grouped under the

Just Accepted

higher-level axial code "Software Product Improvement," as they all reflect motivations or benefits associated with using AIBOMs to improve software products. Together, open and axial coding enabled us to synthesize the extracted data and answer our RQs.

3.3 Reporting the Review

The final phase of our MLR was the reporting of findings. In line with the guidelines for systematic reviews [57, 68], we carefully planned this phase to ensure our results are valuable to practitioners and researchers. For each RQ (see Section 4), we present the identified codes organized under their corresponding broader themes (axial codes). For each code, we indicate the number of sources that reported it in parentheses. In addition to reporting each code and the number of sources that mentioned it, we also include information from sources that elaborated on the code beyond a mere mention. To ensure transparency in the presentation of the results, we distinguish between FL and GL by using separate bibliographic identifiers: FL sources are assigned the prefix "FL," while GL sources are assigned the prefix "GL." In addition, to assess the degree of convergence or divergence between FL and GL, we cross-checked the claims emerging from GL with those identified in FL whenever possible.

A single source may contribute to multiple codes (also for the same RQ). Although codes reported by one or two sources might not be meaningful, we reported them because it is common in MLRs (*e.g.,* [45, 69, 80, 87]). They could still offer valuable insights in specific contexts or highlight unique perspectives worth further exploration. This is especially relevant in the case of AIBOMs, a new and rapidly evolving area where the literature is still taking shape. For example, novel approaches or early-stage practices may not yet have gained widespread attention. Including low-frequency codes allows for a more comprehensive and inclusive synthesis that acknowledges the diversity of viewpoints and experiences present in the current body of knowledge. While outcomes should be interpreted with caution, they help ensure that potentially important but underrepresented aspects are not overlooked and may inform future research directions or practical discussions.

We also highlight implications and actionable insights for practitioners, as well as possible future research directions for researchers. To further enhance the paper's attractiveness, following the guidelines for conducting MLRs [57], we also adopted a structure for the title of this paper proven to be appealing to both reseaerchers and practitioners, namely the *"What we know about..."* pattern [47, 48, 53, 55, 56, 60, 63, 85].

Finally, we openly shared our review dataset as supplementary material [74]. By making our extracted data and synthesis outcomes available in a structured and publicly accessible format, we promote transparency, support replication, and enable reuse or extension in future studies.

4 Results

In this section, we first report descriptive statistics from the analyzed sources and then we report results for each studied research question.

4.1 Statistics on the Analyzed Sources

Figure 3 presents the number of sources published yearly. The first source was published in 2019, followed by three years of publication inactivity (2020-2022). Publication activity resumed in 2023 with nine sources and peaked in 2024 with 25 sources (more than double the previous year). By February 2025, five additional sources will have been published, suggesting that the upward trend will likely continue.

Figure 4 shows the distribution of the types of sources for FL and GL. Blog post is the largest single type of sources, accounting for 15 of the 40 sources (37.5%), followed by conference papers, accounting for 6 of the sources (15%). Both journal and news articles account for 4 of the sources (10%), while each of the workshop paper, white paper, pre-print, and presentation accounts for 2 of the sources (5%). We find documentation, poster, and social media post, each accounting for one of the sources (2.5%).

Just Accepted

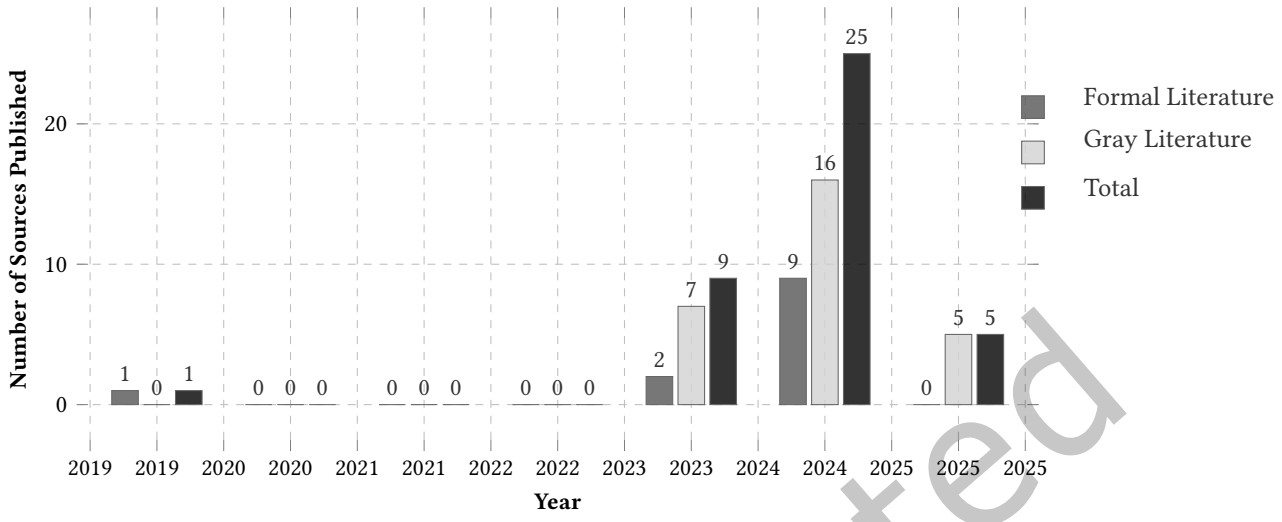

Fig. 3. Number of sources published per year (up to February 2025).

Table 4. Number of FL sources per venue.

Venue	#Total
IEEE/ACM International Conference on Software Engineering	2
IEEE/ACM International Conference on AI Engineering—Software Engineering for AI	2
ACM Transactions on Software Engineering and Methodology	2
Concurrency and Computation: Practice and Experience	1
IEEE International Conference on Blockchain	1
IEEE/ACM International Conference on Program Comprehension	1
IEEE/ACM International Workshop on Engineering and Cybersecurity of Critical Systems & IEEE/ACM International Workshop on Software Vulnerability	1
International Workshop on Science Gateways	1
The Journal of Defense Modeling and Simulation	1

Finally, Table 4 presents the venues—both conference proceedings and journals—where the FL sources were published, along with the corresponding publication counts. The FL sources are published across different venues, with no single venue standing out as prevailing. The venues with the highest number of publications—each featuring two papers—are: the IEEE/ACM International Conference on Software Engineering, the IEEE/ACM International Conference on AI Engineering–Software Engineering for AI, and the ACM Transactions on Software Engineering and Methodology.

4.2 RQ1. What are the motivations and benefits of using AIBOMs?

We identified 17 distinct motivations and benefits for using AIBOMs, each targeting improvements in either software products or processes (see Table 5). In the following, we elaborate on each motivation/benefit, categorizing them into those that improve software products and those that improve software processes.

4.2.1 Improvement of Software Products. **Transparency** (35) is the most frequently mentioned motivation and benefit for using AIBOMs. As AI-enabled systems become increasingly widespread, it is vital to ensure

Just Accepted

Fig. 4. Overview of literature source types using a sunburst chart.

Just Accepted

the transparency of both traditional and AI components [GL24, GL31]. Due to their nature, AI components are characterized by greater complexity and opacity than traditional software components [GL20]. AIBOMs achieve transparency by providing a clear and detailed inventory of all components constituting an AI-enabled system [FL8][GL19, GL23, GL34]. This inventory includes models, data sources, synthetic data, hardware, tools, and methodologies employed in the development and delivery of AI-enabled systems [FL8][GL19, GL23, GL34].

AIBOMs can also be used for supporting **traceability** (12), that is, to track the provenance of the components constituting AI-enabled systems [FL2, FL12][GL21]. For example, AIBOMs can track the lineage of AI models, their intended use, where they came from, and how they were trained [GL17]. Regarding the various datasets that might have been employed, traceability enables the tracking of data flow from its origin to its final storage or use [FL4].

Transparency and traceability enable several other benefits/motivations for using AIBOMs [GL34, GL39]. For example, an in-depth understanding of the components constituting an AI-enabled system could help assess how these components affect **reliability** (2), **safety** (10), or **security** (24). As for security, AIBOMs facilitate managing risks originating from vulnerabilities and supply chain attacks [GL13, GL37]. Since AI models may

Table 5. Summary of codes for RQ1.

Axial Codes	Codes	#Total	#FL	#GL	FL Sources	GL Sources
Software Product Improvement	Transparency	35	10	25	[FL2, FL3, FL5–FL12]	[GL13–GL27, GL29–GL35, GL37–GL39]
	Security	24	4	20	[FL1, FL2, FL7, FL9]	[GL13–GL16, GL18, GL20–GL25, GL27, GL29, GL31, GL32, GL36–GL40]
	Responsibility	21	5	16	[FL4, FL5, FL7, FL11, FL12]	[GL15, GL16, GL18, GL19, GL23, GL26, GL27, GL30, GL32–GL38, GL40]
	Trust	15	4	11	[FL2, FL4, FL7, FL8]	[GL13, GL17, GL19, GL23, GL26, GL29, GL32, GL33, GL37, GL38, GL40]
	Accountability	14	6	8	[FL2–FL4, FL7, FL10, FL11]	[GL15, GL19, GL23, GL25, GL29–GL31, GL38]
	Traceability	12	6	6	[FL1–FL4, FL11, FL12]	[GL14, GL17, GL21, GL23, GL32, GL33]
	Safety	10	1	9	[FL11]	[GL13, GL14, GL16, GL18, GL19, GL21, GL24, GL34, GL39]
	Reproducibility	6	2	4	[FL4, FL8]	[GL18, GL19, GL23, GL38]
	Reliability	2	1	1	[FL4]	[GL33]
	Explainability	1	1	0	[FL2]	
Software Process Improvement	Regulatory Compliance	21	4	17	[FL4, FL5, FL7, FL11]	[GL13, GL14, GL17–GL19, GL21–GL23, GL26, GL27, GL29–GL34, GL37]
	Risk Management	19	3	16	[FL3, FL7, FL11]	[GL13–GL16, GL18, GL21–GL23, GL27, GL29, GL30, GL32, GL34, GL37, GL38, GL40]
	License Compliance	10	3	7	[FL4, FL7, FL12]	[GL13, GL14, GL24, GL27, GL30, GL32, GL37]
	Procurement	6	1	5	[FL5]	[GL18, GL20, GL26, GL37, GL40]
	Collaboration	4	0	4		[GL18, GL22, GL27, GL37]
	Maintenance and Evolution	4	1	3	[FL11]	[GL25, GL32, GL34]
	Automation	3	0	3		[GL13, GL15, GL17]

require software libraries to run, process inputs and outputs, and use hardware, these libraries constitute vectors for potential vulnerabilities and supply chain attacks [GL13]. A further security risk is represented by source code generated through AI models trained on compromised datasets [GL37]. AIBOMs could be leveraged to identify and track the provenance of code generated by AI models.

Responsibility (21) represents another important motivation/benefit. AIBOMs help ensure that AI-enabled systems are developed and deployed responsibly, thus meeting ethical standards [FL7][GL33, GL34]. This is possible because AIBOMs can also document considerations about possible biases or limitations of AI models [GL19, GL23]. Eventually, AIBOMs can also help determine liability when AI-enabled systems cause harm or make erroneous decisions [FL11]. Responsibility is closely associated with **accountability** (14). AIBOMs can offer a tangible record against which stakeholders can be identified and held accountable for their decisions and operations [FL4, FL7]. AIBOMs ensure accountability as stakeholders would be aware of the origins, components, and performance metrics of AI-enabled systems [GL19, GL23]. Such accountability is crucial as society demands increasing accountability for such systems, which are increasingly used commercially and in the public sector [FL3].

A further motivation for using AIBOMs is building **trust** (15). This is achieved by documenting the components constituting AI-enabled systems, how they work, and how their stakeholders are safeguarded from potential risks [FL7][GL37, GL38]. An AIBOM (like any other kind of BOM) can also offer enough information for **reproducibility** (6). That is, AIBOMs can provide researchers and developers with enough information to recreate/reproduce the AI-enabled system it describes, including its AI components and their behaviors/results [GL19, GL23]. Reproducibility can also involve data, *e.g.,* operations to transform a dataset from one version to another [FL4]. Lastly, an AIBOM could support **explainability** (1).

4.2.2 Improvement of Software Processes. **Regulatory compliance** (21) was the most mentioned motivation and benefit for using AIBOMs to improve software processes. As AI becomes increasingly pervasive, new rules, laws, directives, and regulations are likely to be introduced and followed [GL18, GL23, GL31, GL33, GL34]. AIBOMs can be pivotal in ensuring and demonstrating regulatory compliance of AI-enabled systems [GL18, GL23, GL31, GL33,

Just Accepted

GL34]. In particular, industries subjected to strict regulations (*e.g.,* healthcare or manufacturing) might benefit from AIBOMs to safeguard user data privacy and copyright [GL19, GL23]. Other aspects that might be regulated, and for which AIBOMs can be useful, relate to provenance. For example, regulations might impose restrictions on where the training data is sourced, where the infrastructure is based, or where the AI model is deployed and available for use [FL4][GL23]. Another aspect to which AI needs to comply is licensing. AIBOMs also document licensing information and, thus, support **license compliance** (10). Just like traditional software components, AI components have (and may inherit) licenses, which might be very permissive (*e.g.,* Apache 2.0 license) or restrictive (*e.g.,* copyleft licenses) [GL13]. In addition, the different parts of an AI model (*e.g.,* training data or architecture) can each be separately licensed [GL13]. Licensing also involves AI-generated code [FL12][GL37].

AIBOMs support the **automation** (3) of software processes. AIBOMs are typically distributed as JSON or HTML files [GL15] and follow a unified standard like SPDX or CycloneDX [GL17]. Therefore, the list of components provided by AIBOMs is structured and machine-readable [GL13, GL17]. This enables stakeholders to automate a variety of activities, such as responding to security incidents [GL13, GL15]. AIBOMs also support **collaboration** (4) within organizations [GL18] and the **maintenance and evolution** (4) of AI-enabled systems. The latter motivation/benefit is particularly important when dealing with AI components because, differently from traditional software that once deployed remains static in its behavior, AI models may evolve as they process new data [FL11].

AIBOMs can be leveraged for the **procurement** (6) of AI components. For example, a primary concern of the US Army is adopting the best AI components from industry into their systems [GL20, GL40]. In doing so, the US Army must be assured about the safety of the AI models it relies on, especially because it has to re-train such models for military purposes using sensitive or classified data [GL20]. In general, AIBOMs provide support to **risk management** (19) by mitigating potential threats emerging from AI [FL7][GL15, GL34, GL37, GL38]. For example, an AIBOM can help detect and then address issues like outdated libraries, insecure dependencies, or issues with datasets or models [GL38].

4.2.3 Answering RQ1. Drawing on the findings obtained, we present our answer to RQ1 in the box below.

> The most mentioned benefits for the *improvement of software products* are improved **transparency** and **traceability**. Both have important impact for **security** and **safety**. In terms of *software process improvement*, AIBOMs are particularly important for **regulatory compliance**. They are considered to help organizations meet legal and industry standards, but also help to increase **trust**, and aid **risk management**.

Notes: Both GL and FL consistently support similar findings. Notably, some claims are reported across both types of sources, *e.g.,* those concerning transparency, traceability, responsibility, trust, and risk management.

4.3 RQ2. What are the laws and regulations related to using AIBOMs?

We identified 21 laws/regulations related to the use of AIBOMs (see Table 6). We organized these laws/regulations into five broad categories based on the regulatory bodies that proposed them. These regulatory bodies are: *(i)* international organizations, *(ii)* European Union, *(iii)* United States, *(iv)* Canada, *(v)* Singapore, and *(vi)* China.

4.3.1 International Organizations. The **ISO/IEC 42001 - AI Management System Standard** (3) was introduced by the International Organization for Standardization (ISO) and the International Electrotechnical Commission (IEC). It establishes governance across the AI lifecycle [GL38]. AIBOMs facilitate compliance with ISO/IEC 42001 by providing structured documentation of model provenance, training data sources, and security controls [GL38]. We also identified the **IEEE Ethical Technology Standards - P70xx series** (1), developed by the Institute of Electrical and Electronics Engineers (IEEE). These standards specify the essential documentation required to support ethical AI handling [GL14]. Bennet *et al.* [GL14] examined the compliance of the SPDX 3.0 standard

Just Accepted

Table 6. Summary of codes for RQ2.

Axial Codes	Codes	#Total	#FL	#GL	FL Sources	GL Sources
International Organizations	IEEE Ethical Technology Standards - P70xx series	1	0	1		[GL14]
	ISO/IEC 42001 - AI Management System Standard	3	0	3		[GL14, GL17, GL38]
	National Institute of Standards and Technology (NIST) AI Risk Management Framework	3	0	3		[GL17, GL32, GL38]
Canada	Principles for responsible, trustworthy and privacy-protective generative AI technologies	1	0	1		[GL35]
China	Basic security requirements for generative artificial intelligence service	1	0	1		[GL35]
	Measures for the Management of Generative Artificial Intelligence Services	2	0	2		[GL19, GL35]
	Personal Information Protection Law of the People's Republic of China	1	0	1		[GL35]
European Union	EU AI Act	7	0	7		[GL14, GL17, GL19, GL30, GL31, GL35, GL38]
	EU General Data Protection Regulation - GDPR	4	2	2	[FL4, FL12]	[GL19, GL35]
	EU Product Liability Directive	1	1	0	[FL11]	
	European Medicines Agency (EMA) Requirements for Medical Devices	1	0	1		[GL14]
Singapore	Model ai governance framework for generative ai	1	0	1		[GL35]
United States	California Consumer Privacy Act	2	0	2		[GL31, GL35]
	Cyber Supply Chain Management and Transparency Act	1	1	0	[FL7]	
	Internet of Things Cybersecurity Improvement Act	1	1	0	[FL7]	
	US Copyright Law	1	1	0	[FL12]	
	US Executive Order 13960 - Promoting the Use of Trustworthy Artificial Intelligence in the Federal Government	1	0	1		[GL30]
	US Executive Order 14028 - Improving the Nation's Cybersecurity	6	3	3	[FL2, FL7, FL8]	[GL15, GL24, GL31]
	US Executive Order 14110 - Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence	3	0	3		[GL23, GL31, GL37]
	US Food and Drug Administration (FDA) Requirements for Medical Devices	1	0	1		[GL14]
	US Health Insurance Portability and Accountability Act	1	0	1		[GL19]

with these IEEE and ISO standards. Their analysis assessed whether SPDX 3.0 includes data fields that capture the information indicated by these IEEE and ISO standards. SPDX 3.0 provides data fields for documenting such information, although those fields are not mandatory. AIBOMs also align with the **National Institute of Standards and Technology (NIST) AI Risk Management Framework** (3). The governance, transparency, and continuous monitoring led by AIBOMs can help organizations document risks across the AI lifecycle, ensuring AI deployments adhere to trustworthy AI principles [GL38].

4.3.2 European Union. The EU is advancing significant regulatory requirements for AI models as part of the **EU AI Act** (7). The latter, effective from 1 August 2024, aims to regulate AI by establishing rules for AI-enabled systems to design and deploy them in compliance with existing laws and fundamental rights [GL14]. The EU AI Act requires that all products with embedded AI must be assessed before being put on the market and throughout their lifecycle [GL19]. This legislation categorizes AI-enabled systems based on their risk levels and imposes more stringent requirements on high-risk applications to enhance transparency and accountability [GL14]. Such risks include safety, security, discrimination, privacy, and licensing [GL30, GL38]. The products subjected to the EU AI Act are not limited to software systems, but they may also include, for example, toys, aircraft, cars, medical

Just Accepted

devices, and elevators [GL19]. The EU AI Act also regulates generative AI [GL35]. For instance, it mandates that AI-generated deepfake content must disclose a machine-readable and detectable watermark indicating that such content has been artificially manipulated [GL35]. AIBOMs enables compliance toward regulations like the EU AI Act by tracking the risks of AI, *e.g.,* by identifying components and assuring proper documentation for audits [GL38]. The SPDX 3.0 standard was designed to comply with the EU AI Act [GL14].

AIBOMs can also facilitate compliance with pre-existing regulations that were not conceived for dealing with AI-enabled systems. For example, in the case of the **EU General Data Protection Regulation - GDPR** (4), AIBOMs can help comply with general privacy requirements such as the right to be informed, the right of access, right to rectification, or right to erasure [FL12][GL35]. Further examples of EU regulations that could be facilitated by AIBOMs are the **European Medicines Agency (EMA) Requirements for Medical Devices** (1) and the **EU Product Liability Directive** (1).

4.3.3 United States. The **US Executive Order 13960 - Promoting the Use of Trustworthy Artificial Intelligence in the Federal Government** (1) introduced principles required for understanding AI technologies used in software systems, including accountability, transparency, responsibility, traceability, and regulatory monitoring [GL30]. The **US Executive Order 14028 - Improving the Nation's Cybersecurity** (6) paved the way for the large-scale adoption of SBOMs. It mandated software vendors to distribute the SBOMs of the software products commercialized to the US government [FL8][GL15]. Software products that incorporate AI components must still comply with this regulation and, thus, use AIBOMs. The Executive Order 14028 was anticipated by previous regulations [FL7], such as the **Cyber Supply Chain Management and Transparency Act** (1) and the **Internet of Things Cybersecurity Improvement Act** (1). More recently, the **US Executive Order 14110 - Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence** (3) was released. It aims to shape the priorities for future laws concerning AI [GL23]. Similarly to the EU AI Act, the Executive Order 14110 may require the disclosure of material created with generative AI, such as via an electronic watermark [GL37]. AIBOMs following SPDX 3.0 proved to be valid also with respect to the **US Food and Drug Administration (FDA) Requirements for Medical Devices** (1) [GL14]. AIBOMs could also help to deal with copyrighted content in the training of AI models and copyright infringements [FL12], thus facilitating the **US Copyright Law** (1). Other regulations that have been introduced in the US to regulate AI are the **California Consumer Privacy Act** (2) and the **US Health Insurance Portability and Accountability Act** (1).

4.3.4 Canada. Canadian regulators released the guidance **Principles for responsible, trustworthy and privacy-protective generative AI technologies** (1), which enforces requirements related to AI, such as AI-generated watermarking [GL35]. This guidance could be facilitated by AIBOMs.

4.3.5 Singapore. Singapore regulators released the **Model AI Governance Framework for Generative AI** (1), which enforces requirements related to generative AI, such as AI-generated watermarking [GL35]. This framework could be supported by AIBOMs.

4.3.6 China. China's **Measures for the Management of Generative Artificial Intelligence Services** (2) resembles an AIBOM-like requirement [GL19]. Accordingly, foundation models embedded in public-facing AI-enabled systems must be registered with governments [GL19, GL35]. China also has other regulations that could be facilitated through AIBOMs. These are **Personal Information Protection Law of the People's Republic of China** (1) and the **Basic Security Requirements for Generative Artificial Intelligence Services** (1).

4.3.7 Answering RQ2. Drawing on the findings obtained, we present our answer to RQ2 in the box below.

Just Accepted

Table 7. Summary of codes for RQ3.

Axial Codes	Codes	#Total	#FL	#GL	FL Sources	GL Sources
Datasets	Characteristics	3	1	2	[FL8]	[GL14, GL39]
	Processing	8	3	5	[FL1, FL7, FL8]	[GL13, GL14, GL24, GL38, GL39]
	Sensors	3	0	3		[GL14, GL18, GL39]
Models	Architecture	9	2	7	[FL7, FL8]	[GL13, GL14, GL23–GL25, GL28, GL33]
	Authenticity	9	2	7	[FL4, FL7]	[GL13, GL18, GL23, GL24, GL33, GL37, GL38]
	Autonomy	2	0	2		[GL14, GL34]
	Explainability	2	0	2		[GL14, GL34]
	Performance	4	0	4		[GL14, GL28, GL32, GL34]
	Safety	2	0	2		[GL14, GL34]
	Security	6	1	5	[FL7]	[GL16, GL25, GL27, GL38, GL39]
	Sustainability	9	1	8	[FL7]	[GL13, GL14, GL18, GL23, GL24, GL28, GL33, GL34]
	Training	20	4	16	[FL7, FL8, FL10, FL11]	[GL13–GL15, GL20, GL21, GL23–GL25, GL28, GL29, GL31, GL32, GL34, GL38–GL40]
	Usage	13	2	11	[FL3, FL7]	[GL13–GL15, GL21, GL23, GL24, GL28, GL33, GL34, GL38, GL39]
Models and Datasets	Authorship	13	3	10	[FL1, FL3, FL7]	[GL13, GL14, GL16, GL21, GL23, GL24, GL28, GL33, GL37, GL38]
	Dependencies	13	1	12	[FL7]	[GL13, GL16, GL23–GL25, GL27, GL29, GL31–GL33, GL38, GL39]
	Ethical Considerations	12	2	10	[FL7, FL8]	[GL13, GL14, GL18, GL23, GL24, GL27–GL29, GL33, GL38]
	Identifiers	19	7	12	[FL1, FL3, FL4, FL7, FL8, FL10, FL11]	[GL13, GL14, GL16, GL21, GL23, GL24, GL27–GL29, GL33, GL37, GL38]
	Licenses	17	4	13	[FL3, FL4, FL7, FL12]	[GL13–GL16, GL21, GL24, GL25, GL27, GL28, GL32, GL33, GL37, GL38]
	Limitations	3	0	3		[GL14, GL28, GL34]
	Privacy	2	0	2		[GL14, GL34]
	Provenance	12	4	8	[FL1, FL7, FL8, FL10]	[GL13, GL14, GL21, GL23, GL24, GL29, GL32, GL33]
	Standards	2	0	2		[GL14, GL34]
	Type	10	1	9	[FL7]	[GL13, GL14, GL23, GL24, GL32–GL34, GL38, GL39]

Standards like **ISO/IEC 42001**, **IEEE P70xx**, and the **NIST AI Risk Management Framework** promote responsible AI governance, ethics, and risk management—areas where AIBOMs contribute by documenting information related to AI components. In the *European Union*, the **EU AI Act** requires transparency, risk classification, and documentation for AI-enabled systems. AIBOMs help meet these demands, as well as those under **GDPR**, **EMA Requirements for Medical Device**, and **Product Liability Directive**. In the *United States*, several executive orders (including **EO 13960**, **EO 14028**, and **EO 14110**) and laws (including **Copyright Law**, **Cyber Supply Chain Management and Transparency Act**, and **Internet of Things Cybersecurity Improvement Act**) emphasize AI transparency, security, responsibility, and accountability. AIBOMs are believed to guarantee these attributes.

Notes: No contradictions emerged between claims and some were supported by both types of sources (*e.g.*, those related to the EU GDPR and US Executive Order 14028). However, we acknowledge that a large number of regulations are supported exclusively by GL—such as those related to international organizations, Canada, or China—as they were not reported in any FL sources.

4.4 RQ3. What elements are included or worth including in AIBOMs?

Based on our open coding, we identified 23 elements that are included (or worth including) in AIBOMs (see Table 7). We organized these elements into three broad categories based on whether they pertain to the models, datasets, or both. In the following, we elaborate on each of them.

Just Accepted

4.4.1 Models and Datasets. **Identifiers** (19) stand out as the most common elements worth including in AIBOMs for both models and datasets. These elements can be used to represent both name and versions of models and datasets [FL1, FL3, FL4, FL7, FL8, FL10, FL11][GL13, GL14, GL16, GL21, GL23, GL24, GL27–GL29, GL33, GL38]. Identifiers can be also used to indicate the name and path of the files with AI-generated code [GL37].

Other elements worth including in AIBOMs for both models and datasets are **licenses** (17). These elements provide a standardized way of communicating licensing information about models and datasets, making it easier to comply with license obligations for AI-enabled systems [GL13, GL14]. Licenses can also be associated with AI-generated code [FL12][GL37].

Authorship (13) facilitates tracking the origin of components by identifying their suppliers [GL14]. Examples of these elements are the names of the individuals and/or organizations owning, curating, managing, or distributing a given model or dataset [GL13, GL14, GL24, GL28]. In AI-generated code, authorship may relate to the developer who added such code [GL37].

Dependencies (13) may indicate any libraries that a given component relies upon [FL7][GL13]. In the case of AIBOMs, dependencies may indicate the functions, tools, and datasets used to facilitate the development, training, and deployment of ML models [GL25].

Ethical considerations (12) outline how potential ethical concerns are addressed and mitigated, including privacy violations or racial bias [GL13, GL14, GL24]. These concerns can introduce bias in model predictions [GL14]. For datasets, ethical concerns may arise due to: *(i)* selection bias, where the collected data fails to represent the target population accurately; *(ii)* measurement bias, which occurs when the accuracy of the measurements varies; and *(iii)* label bias, when the labels used to categorize the data are biased in some way [GL14].

Other elements that help track the origin of components relate to **provenance** (12). They can link to the source of the training datasets or the place where the model can be accessed/downloaded, such as Hugging Face [GL13, GL14, GL24]. Provenance may also indicate if datasets pertain to customer, open-source, or synthetic data [GL32], as well as the data collection approach (*e.g.,* mining repositories or interviews) [GL14].

For any given model or dataset, AIBOMs can support the inclusion of elements describing its **type** (10). For models, this includes indicating whether the asset is, for example, a neural network, decision tree, text generation system, image processing model, or a learning paradigm such as supervised, unsupervised, or reinforcement learning—or a combination thereof [GL13, GL14, GL24, GL34]. Additionally, the application domain (*e.g.,* computer vision, healthcare, finance, or automotive) can be specified to provide further information [GL14, GL34]. For datasets, the type can denote whether the data is personal or sensitive [GL32], and may also include the variety of data formats involved, such as textual or images [GL14]. Furthermore, datasets may be characterized by their structure, distinguishing between unstructured content and structured data typically organized in tabular formats or sourced from relational databases [GL14].

Limitations (3) can be explicitly documented in AIBOMs to highlight areas where a model or dataset may fall short [GL34]. For models, limitations may pertain to factors that impact performance negatively [GL28] or limited generalization to new/unseen data [GL14]. In the case of datasets, limitations might include issues such as class imbalance or overfitting due to insufficient data diversity [GL14].

AIBOMs could also report information related to **privacy** (2). This would refer to any sensitive personal data processed by a model or included in datasets [GL14, GL34]. AIBOMs could describe the methods used to anonymize the dataset or fields in the dataset (*e.g.,* pseudonymization, k-anonymity, l-diversity, or t-closeness), the confidentiality level, and the presence of sensitive personal information [GL14].

AIBOMs could also report the **standards** (2) that a system adheres to [GL14, GL34]. This could prove that the system meets published or unpublished standards, such as those developed by ISO, IEEE, and ETSI [GL14]. The standards may, but are not necessarily required to, satisfy legal or regulatory requirements [GL14].

Just Accepted

4.4.2 Models. **Training** (20) stands out as the most common element worth including in AIBOMs to document the training phase of the model. Training information includes the techniques, algorithms, configurations, hardware, and software used to develop models, which are essential for understanding and reproducing results [GL13, GL24, GL34, GL39]. Key among these are hyperparameters—predefined settings like learning rate, batch size, and number of layers—that significantly influence model behavior and performance [FL8][GL14, GL15, GL28, GL32, GL34, GL38–GL40]. Proper selection and tuning of these hyperparameters are crucial for effective learning, ultimately leading to better predictive performance and more reliable outcomes [GL14, GL34]. Links to the datasets used to train, validate, and test the models can also be made explicit [FL7, FL8, FL11][GL14, GL25, GL28, GL38].

Other elements worth including in AIBOMs for models relate to the **usage** (13) and **architecture** (9). As for usage, the elements include the hardware and software required to run the model, the expected input and output, as well as intended, improper, or malicious uses [FL3, FL7][GL13–GL15, GL21, GL23, GL24, GL33, GL38, GL39]. As for architecture, the information of the elements are arranged into the following four groups:

(i) *Model architecture* [GL13, GL23, GL24, GL33]. It provides details on the specific architecture of the model, including its structure, layers, nodes, activation functions, and any specialized components [FL7][GL14, GL28]. If applicable, it may also indicate the name of such architecture, *e.g.,* GPT-J, GPT-1, ResNet-50, or YOLOv3 [GL13, GL28].

(ii) *Architecture family* [GL13, GL23, GL24, GL28, GL33]. It details the model architecture family, such as transformer network, convolutional neural network, residual neural network, or LSTM neural network [GL28]. If applicable, it may also indicate the name of the architecture family or class, *e.g.,* Llama 2 [FL7][GL13].

(iii) *Base model* [FL7, FL8][GL13, GL24, GL25, GL33]. It provides details on the name, version, and source of the base (or "foundation") model on which the current model is based, if any [FL7][GL24]. A base model can act as a starting point for fine-tuning or transfer learning on specific tasks, thus it serves as a foundation for building more complex models [GL25].

(iv) *Parent model* [FL7][GL13, GL23, GL24, GL33]. It provides details on the name, version, and source of the parent model that the current model is based on, if any [FL7][GL24]

Elements related to the **authenticity** (9) of a model encompass certifications, attestations, and verifications—digitally signed by the model creator—that establish the model's credibility and demonstrate compliance with relevant standards and regulations [FL7]. Such information can also help ensure the integrity of the model [GL13, GL24, GL38] and may be delivered through blockchain-based mechanisms, such as smart contracts [FL4]. In the case of AI-generated code, authenticity may be expressed as a confidence level indicating the likelihood that the code was produced by an AI model [GL37].

The primary concern regarding **sustainability** (9) is environmental impact [GL13, GL14, GL24, GL33, GL34] and, in particular, the energy consumption required to train, fine-tune, and operate AI models [GL13, GL14, GL18, GL23, GL24, GL28]. For instance, large language models often require substantial computational resources; estimates suggest that a single large language model can release as many carbon emissions as five cars over their entire life-cycle [GL14]. This can lead to significant environmental impact, especially when training occurs in data centers powered by non-renewable energy sources [GL14]. This contributes to carbon footprint and carbon emissions (*e.g.,* release of carbon dioxide, also known as CO_2), with potential impacts on climate change [GL13, GL14, GL24]. Another relevant concern is using physical resources such as water for cooling data centers [GL14]. Energy consumption estimates can be based on various factors, including details about the computational resources used (*e.g.,* number of floating-point operations), training duration, type and quantity of processing units, and other relevant aspects of the training process [GL14]. Energy units may be specified as kilowatt-hours (kWh) or megajoules (MJ), as well as other alternative units [GL14]. For example, the training of a deep learning neural network for image classification has been reported to consume 980 kWh of energy; fine-tuning consumed

Just Accepted

an additional 15 kWh; and inference, when the model is deployed, was reported to consume approximately 80 watt-hours of energy [GL14].

Security (6) elements that can be reported in AIBOMs encompass vulnerabilities and other security requirements (*e.g.,* encryption methods, access controls, and governance measures) [FL7][GL25, GL38]. Information about vulnerabilities relevant to the AI-enabled system (*e.g.,* LLM Vulnerabilities & Exposures) can be taken from databases such as the NVD and CVE, along with their severity ratings and potential impact [FL7][GL25]. Metrics related to **performance** (4) can be reported in AIBOMs to document how the model was evaluated and to guide future improvements [GL14, GL34]. Common metrics include accuracy, precision, recall, F1-score, ROC curve, AUC, MSE, MAE, RMSE, R-squared, and relevant benchmarks [GL14]. AIBOMs may also document any trade-offs in accuracy or performance made during the model's construction, training, and application [GL34]. **Safety** (2) elements could cover the comprehensive assessment of safety risks associated with an AI-enabled system [GL14, GL34]. This includes identifying and integrating various risk levels and considerations to better understand and mitigate potential threats posed by each model [GL14, GL34]. As in SPDX, these risk levels should align with established regulations, such as the EU General Risk Assessment Methodology, which supports the implementation of Article 20 of Regulation (EC) No 765/2008 and aids authorities in evaluating general product safety compliance [GL14, GL34]. The standardized safety risk levels are defined as follows:

(i) *Serious* [GL14, GL34]. Critical risk requiring immediate attention (*e.g.,* self-driving vehicles);
(ii) *High* [GL14, GL34]. Significant risk necessitating stringent controls (*e.g.,* adaptive education systems);
(iii) *Medium* [GL14, GL34]. Moderate risk that warrants balanced mitigation strategies (*e.g.,* bank loan approvals);
(iv) *Low* [GL14, GL34]. Minimal risk with limited safety concerns (*e.g.,* shopping recommendation).

Developers are expected to classify their application's safety risk level based on the intended use and target audience [GL14]. AIBOMs could also describe the level of decision-making **autonomy** (2). It relates to whether, and to what extent, the system can perform a decision or action without human involvement or guidance [GL14, GL34]. In other words, it should indicate whether humans are involved "in the loop" to validate the AI-enabled system's decision-making process [GL14]. Examples of systems where humans are not in the loop include self-driving cars, autonomous robots, and virtual assistants [GL14]. In contrast, systems that typically involve human oversight include mortgage loan approvals, financial investment decisions, and applications within the justice system [GL14]. **Explainability** (2) elements could indicate how well it is possible to understand how the model arrived at its predictions, decisions, or recommendations, and why it made those choices [GL14, GL34]. These elements may also report the different explainability mechanisms that can be used to explain the results from the AI model—*e.g.,* SHapley Additive exPlanations (SHAP) and Local Interpretable Model-Agnostic Explanations (LIME) [GL14]. The goal of model explainability is to make AI-enabled systems more transparent, trustworthy, and accountable [GL14, GL34].

4.4.3 Datasets. **Processing** (8) stands out as the most common element worth including in AIBOMs for datasets. It encompasses all procedures that led to creating a given dataset before being used [GL13, GL14, GL24]. These procedures include data collection, curation, cleaning, transformation, augmentation, sampling processes, and update [FL7][GL14, GL39]. Detailed information may include methods for tokenization, normalization, standardization, or deduplication [GL14, GL39]. As for the update procedures, these can be batch, real-time (*e.g.,* stock prices), incremental (*e.g.,* social media or news feeds), or manual (*i.e.,* requiring human verification) [GL14].

For systems operating in physical domains, **sensors** (3) used for data collection can be reported in AIBOMs [GL14, GL18, GL39]. This might also involve calibration information and how the values are stored (*e.g.,* in a key-value format and the names of such keys) [GL14]. Other elements related to datasets that can be included in AIBOMs are the **characteristics** (3), such as the size (*e.g.,* in terms of bytes) and labeling [FL8][GL14, GL39].

Just Accepted

Table 8. Summary of codes for RQ4.

Axial Codes	Codes	#Total	#FL	#GL	FL Sources	GL Sources
Compliance	Enforcing Intellectual Property	5	1	4	[FL11]	[GL14, GL27, GL32, GL38]
	Enforcing Regulations	10	1	9	[FL7]	[GL13, GL14, GL21, GL22, GL27, GL29, GL30, GL32, GL38]
Dependability	Security-by-Design	9	3	6	[FL2, FL7, FL8]	[GL13, GL14, GL22, GL24, GL32, GL38]
	Responding to Vulnerabilities	12	3	9	[FL2, FL7, FL9]	[GL14, GL18, GL21, GL22, GL24, GL27, GL31, GL32, GL38]
	Supporting Troubleshooting	3	1	2	[FL7]	[GL13, GL33]
Management	Managing AIOps Pipelines	10	2	8	[FL7, FL10]	[GL13, GL18, GL21, GL27, GL29, GL32, GL33, GL39]
	Managing Communication	1	1	0	[FL5]	
	Managing Models	9	4	5	[FL3, FL6, FL7, FL11]	[GL14, GL18, GL27, GL32, GL38]
	Managing Third-party AI Components	12	2	10	[FL6, FL7]	[GL14, GL15, GL20, GL24, GL27, GL29, GL31, GL32, GL37, GL38]

4.4.4 Answering RQ3. Drawing on the findings obtained, we present our answer to RQ3 in the box below.

For both *models and datasets*, the analyzed sources recommend including **provenance** information, including **authorship**, **licensing**, or **dependencies**, as well as **limitations**/weaknesses, such as bias or privacy issues. For *datasets*, it is particularly important to detail information describing how the dataset has been produced. For *models*, relevant elements to include pertain to their **architecture** and **training**, including models' hyperparameters, and process-related information, *e.g.,* the infrastructure used to build the model and energy consumption or carbon emissions.

Notes: Both GL and FL consistently report similar findings. Notably, several claims are shared across both types of sources, including those related to model and dataset identifiers and licenses and model training, usage, and architecture.

4.5 RQ4. What are the use cases where AIBOMs are used?

Our open coding resulted in the identification of nine use cases for AIBOMs (see Table 8), which we organized into three broad categories based on whether they pertain to management, compliance, or dependability. In the following, we elaborate on each of them.

4.5.1 Management. **Managing third-party AI components** (12) is one of the most prominent and well-documented use cases for AIBOMs. The AI supply chain is inherently complex and involves several third-party components [FL7]. As more organizations seek to embed AI into their systems [GL20], the risks associated with third-party components become increasingly significant [GL32]. To mitigate these risks, it is essential to properly evaluate third-party open-source models and datasets before their adoption [GL32]. AIBOMs enhance transparency by offering visibility into the provenance and characteristics of these components, enabling practitioners to proactively assess and manage associated risks [FL7][GL29]. AIBOMs can be used in evaluation and procurement processes to identify and select trustworthy assets [GL15, GL27, GL31]. For example, the US Army has planned the use of AIBOMs to evaluate AI models under consideration for military applications, to test, retrain, and further evolve these models as needed [GL20].

AIBOMs are also expected to play a pivotal role in **managing AIOps pipelines** (10) [GL27, GL33]. For instance, they can help ensure that AI models are developed, deployed, and maintained in a responsible and transparent manner [GL33]. Similar to SBOMs, AIBOMs should be automatically generated and integrated into pipelines for auditing and compliance purposes [GL13, GL39]. However, AIOps pipelines present unique characteristics, such as the need for continuous training to address data or concept drift [FL10].

In general, the use of AIBOMs supports **managing models** (9), helping to ensure the quality of the AI-enabled systems in which such models are embedded [FL7]. For instance, AIBOMs facilitate model traceability,

Just Accepted

lifecycle management, and streamlined rollback or retraining processes [GL32]. By documenting specific versions, dependencies, and configurations of each component, AIBOMs also enable the identification and mitigation of potential risks [GL27].

AIBOMs could also facilitate **managing communication** (1) between stakeholders, including regulators and users [FL5]. For example, the standardized reporting offered by AIBOMs could be used to inform stakeholders about the development process and product design of AI-enabled systems [FL5].

4.5.2 Compliance. AIBOMs can be used for **enforcing regulations** (9). They help ensure that AI models meet external regulatory requirements, comply with internal policies and standards, and address customer-specific compliance needs [FL7][GL13, GL21, GL27, GL32]. Relevant policies may pertain to privacy [GL27], ethics [FL7][GL29], and legal frameworks [FL7]. AIBOMs can also support **enforcing intellectual property** (5). By documenting and scanning license information, AIBOMs help ensure that AI models comply with intellectual property rights and usage restrictions [GL27, GL32]. This is valuable for various stakeholders. For instance, compliance officers and auditors can verify that AI-enabled systems adhere to licensing requirements, while legal counsels can review contracts, terms of service, and licensing agreements to ensure legal compliance and reduce potential legal risks related to third-party software components [GL27]. AIBOMs can also assist in managing intellectual property concerns related to AI-generated code by helping detect potential exposure of proprietary or sensitive information in generative AI inputs and outputs [GL38].

4.5.3 Dependability. AIBOMs can play a critical role in **responding to vulnerabilities** (12) by enabling their rapid identification and mitigation in case of cybersecurity incidents [FL2][GL32]. By supporting continuous monitoring, AIBOMs help detect AI-specific vulnerabilities and adversarial threats—such as backdoors, model drift, or data poisoning attempts—that may compromise the integrity of AI-enabled systems [GL31, GL38]. For example, if a business analyst or data scientist discovers that a dataset has been poisoned, the AIBOM makes it easier to identify all models that interacted with the compromised data [GL21]. Another threat type, namely model evasion attacks, involves manipulating training data or exploiting weaknesses in the model to bypass security controls and generate false outputs [GL27]. With detailed insight into each component and dependency, development teams can quickly apply patches and update compromised components [FL9]. This proactive identification and response process is essential for preserving model dependability and maintaining the security of the broader systems in which AI is deployed [FL9].

In general, integrating AIBOMs into the software development lifecycle supports the implementation of **security-by-design** principles (9) [GL32]. As with traditional software systems, building AI-enabled systems often involves assembling open-source and commercial components, which may introduce security flaws [FL2]. AIBOMs can function similarly to SBOMs by helping in managing security risks throughout the development process [FL2]. By providing detailed visibility into the components used, AIBOMs enable practitioners to choose models that are better tested, more secure, and pose lower risks [GL13]. They also support tracking external APIs and libraries, alerting stakeholders to known vulnerabilities [GL38]. Additionally, AIBOMs can flag whether a model was trained on potentially poisoned or compromised datasets [FL8].

Besides security, AIBOMs can help in **supporting troubleshooting** (3). AIBOMs facilitate the rapid identification of problematic components when model failure or bias occur, enabling more effective troubleshooting and enhancing overall system dependability [FL7][GL33]. For instance, AIBOMs can assist in debugging issues that arise from upstream model changes [GL13].

4.5.4 Answering RQ4. Drawing on the findings obtained, we present our answer to RQ4 in the box below.

Just Accepted

Table 9. Summary of codes for RQ5.

Axial Codes	Codes	#Total	#FL	#GL	FL Sources	GL Sources
Standard	CycloneDX	10	1	9	[FL11]	[GL15–GL17, GL21, GL23, GL28, GL30, GL32, GL33]
	SPDX	10	1	9	[FL11]	[GL14, GL15, GL17, GL23, GL27, GL32–GL34, GL38]
AIBOM Information Sources	Model Cards	11	3	8	[FL6, FL8, FL11]	[GL13, GL14, GL17, GL25, GL28, GL30, GL33, GL36]
	Datasheets	2	1	1	[FL11]	[GL14]
	Factsheets	1	0	1		[GL14]
	Interactive catalog	1	0	1		[GL38]
Generation	Automated	5	1	4	[FL8]	[GL13, GL23, GL38, GL39]
	Manual	3	0	3		[GL13, GL38, GL39]
	AIBOM generator	1	0	1		[GL38]
	Quasi-AIBOM generator	1	1	0	[FL8]	
Format	JSON	3	0	3		[GL16, GL21, GL33]
	XML	1	0	1		[GL16]
Consumpion	AIBOM visualizer	2	1	1	[FL7]	[GL33]
	Query	1	1	0	[FL3]	
Framework	Blockchain	2	2	0	[FL4, FL11]	
	Enterprise	1	0	1		[GL22]

AIBOMs are considered to play a pivotal role in **managing third-party AI components** by increasing transparency and facilitating risk evaluation during adoption and procurement. They are also relevant to help **managing AIOps pipelines** by enabling responsible, automated, and auditable model deployment. More generally, AIBOMs are relevant to help in **managing models** across their lifecycle. In terms of *compliance*, AIBOMs contribute to **enforcing regulations**, including internal policies and ethical/legal standards, and **intellectual property**, by tracking licensing terms and preventing unauthorized use. As for *dependability*, AIBOMs enhance **responding to vulnerabilities**, including adversarial attacks such as backdoors, model drift, or data poisoning. Using AIBOMs is also important to support **security-by-design** practices, enabling better-informed model choosing and vulnerability tracking throughout development.

Notes: Both GL and FL consistently support similar findings. Notably, several claims are shared across both types of sources, including those related to managing third-party AI components, enforcing regulations, responding to vulnerabilities, and supporting troubleshooting.

4.6 RQ5. What are the approaches, tool categories, and techniques to deal with AIBOMs?

We identified 16 approaches, tool categories, and techniques to deal with AIBOMs (see Table 9), which we organized into six broad categories based on whether they pertain to AIBOM information sources, standards, generation, format, consumption, or framework. In the following, we elaborate on each of them.

4.6.1 Standards. Two standards have emerged for structuring AIBOMs: **CycloneDX** (10) and **SPDX** (10). CycloneDX was extended in version 1.5 to support the documentation of AI-related components [GL21, GL30, GL33]. Similarly, SPDX introduced support for AI-related components in version 3.0 [GL14, GL34]. Notably, the SPDX Working Group—operating under the Linux Foundation—is actively working to complement the existing SPDX ISO Standard (ISO/IEC 5962:2021), which defines the use of SBOMs to document the components involved in building a software system [GL27, GL33].

4.6.2 AIBOM Information Sources. **Model cards** (11), introduced by Ezi Ozoani, Marissa Gerchick, and Margaret Mitchell in a 2022 blog post [GL33], may offer a promising foundation for constructing AIBOMs. Today, major AI ecosystems use model cards to describe models and datasets [FL6, FL8][GL13, GL25]. In this respect, Hugging Face presents model cards that closely align with the goals of SBOMs [GL13, GL28]. Model cards are considered a valuable documentation framework for different stakeholders, including developers, policymakers, ethics experts,

Just Accepted

and end users, as they support understanding, sharing, and improving models and datasets. However, despite their potential, model cards have several critical limitations that prevent them from serving as full replacements for AIBOMs [GL13, GL17]:

- *Lack of standardization.* There is no widely adopted schema defining the structure or minimum content of model cards, leading to inconsistency across models.
- *Not machine-readable.* Most model cards are written as unstructured text intended for human readers, rather than for automated processing.
- *Limited automation.* Due to their informal and inconsistent structure, model cards cannot be reliably generated, parsed, or integrated into automated pipelines.

In addition, model cards often omit critical metadata—such as the datasets used for training—undermining key AIBOM use cases like verifying licensing compliance, identifying security risks, and ensuring ethical sourcing [GL36]. Access restrictions further complicate the use of model cards for AIBOM generation. For example, accessing the full contents of Hugging Face repositories may require user authentication, acceptance of Terms of Service, or other legal agreements [GL36]. In practice, most model cards offer limited actionable information, which reduces their overall utility for AIBOM generation [GL36]. Nonetheless, existing tools for model card generation—such as those provided by Hugging Face and Google's Model Card Toolkit—could be extended or integrated to support AIBOM generation [GL13].

Other information sources that could be a starting point for generating AIBOMs could be **datasheets** (2), **factsheets** (1), and **interactive catalog** (1). The latter may offer a more practical and user-friendly option to design AIBOMs, making it easy to navigate and manage components [GL38].

4.6.3 Generation. Ideally, a mature ecosystem of **automated** (5) AIBOM generators would enable practitioners to generate AIBOMs at negligible cost [GL39]. However, achieving this level of capability would require substantial investment in research and development—estimates suggest that an investment of $2–4 million would be necessary to define, design, and prototype high-quality AIBOM tooling [GL39]. To date, tool support for generating AIBOMs remains scarce, if not nearly nonexistent [FL8]. In the short term, some data is likely to be populated in a **manual** (3) manner until AIBOM generators become more mature [GL13]. The cost of generating an AIBOM manually varies significantly depending on system complexity [GL39]. This cost is usually prohibitive for all but the simplest systems, due to the extensive expertise required to document all relevant components [GL39]. This challenge is further compounded by the fact that much of the necessary information may lie outside the deploying organization, particularly when third-party providers—such as pre-trained model vendors or dataset suppliers—are involved [GL39].

Only one **AIBOM generator** (1) was reported [GL38]. It is a commercial solution that claims to automatically scan AI ecosystems across cloud, on-premises, and third-party services, identifying and cataloging all AI assets, to generate AIBOMs as interactive catalogs. It is worth mentioning the possibility of leveraging also **quasi-AIBOM generators** (1), such as DVC and ML-Flow [FL8].

4.6.4 Format. AIBOMs are structured files that can be provided in various file formats. The file formats found to be reported for AIBOMs are **JSON** (3) and **XML** (1).

4.6.5 Consumption. Among the possible consumption tools—software that reads, interprets, and/or uses AIBOM—a **visualizer** (2) would enable exploring the content of an AIBOM through an interactive visual interface (*e.g.,* https://aibomviz.aisecurityresearch.org) [FL7]. Another way to consume AIBOMs would be to **query** (1) AIBOM data using technologies such as GraphQL [FL3]. Consumption tools would facilitate efficient access, management, and modification of the information contained in an AIBOM.

Just Accepted

Table 10. Summary of codes for RQ6.

Axial Codes	Codes	#Total	#FL	#GL	FL Sources	GL Sources
Consumption	Intellectual Property	4	1	3	[FL8]	[GL15, GL23, GL26]
	Security Auditing	2	0	2		[GL13, GL39]
Generation	Accuracy	3	1	2	[FL8]	[GL15, GL38]
	Available data	3	1	2	[FL12]	[GL13, GL14]
	Capturing Dynamic Aspects	4	2	2	[FL10, FL11]	[GL30, GL39]
	Generators	7	3	4	[FL6, FL8, FL10]	[GL13–GL15, GL30]
Human Aspects	Education	3	0	3		[GL23, GL30, GL39]
	Information Visualization	2	1	1	[FL1]	[GL13]
Interoperability	Interoperability with other BOMs	4	2	2	[FL8, FL11]	[GL18, GL39]
	Interoperability with other existing infrastructure	3	1	2	[FL8]	[GL18, GL39]
Traceability	Predictions	2	1	1	[FL1]	[GL39]

4.6.6 Framework. AIBOMs have been envisioned within frameworks. Considering the decentralized nature of the supply chain, **blockchain** (2) could serve as an infrastructure for managing AIBOMs among diverse stakeholders [FL4, FL11]. For example, a three-tier architecture for blockchain-based AIBOM could comprise three layers: the service layer, which includes an AIBOM generator for automatically capturing metadata from artifacts; the on-chain AIBOM layer, which processes business logic via smart contracts; and the off-chain data layer, where data repositories are maintained by stakeholders themselves instead of being centralized in the platform [FL4].

AIBOMs could also be integrated in **enterprise** (1) architectures. For example, the Unified Architecture Framework [GL22], which is based on work in the defense domain, can support the systematic definition and organization of the components in AIBOMs, ensuring that all relevant elements are covered and properly documented through a common language and set of concepts.

4.6.7 Answering RQ5. Drawing on the findings obtained, we present our answer to RQ5 in the box below.

AIBOM files have generally **JSON** *formats*. Regarding *AIBOM information sources*, **model cards** are the most commonly referenced starting point for AIBOMs, as they help document AI models and datasets. However, model cards face critical limitations such as a lack of standardization, limited machine readability, and minimal automation. As for *standards*, **SPDX** and **CycloneDX** are emerging as crucial in supporting AI-specific extensions of SBOMs. For *generation*, there is currently limited tool support.

Notes: No contradictions emerged between claims, and some were supported by both types of sources, such as those about the use of model cards as AIBOM information sources.

4.7 RQ6. What are the limitations and challenges of AIBOMs?

We identified 12 challenges and limitations related to AIBOMs (see Table 10), which we organized into five broad categories based on whether they pertain to generation, consumption, human aspects, interoperability, or traceability. In the following, we elaborate on each of them.

4.7.1 Generation. The main limitation of current AIBOMs pertains to the lack of mature **generators** (7) [FL8, FL10][GL13, GL15]. This highlights a significant market opportunity for developing AIBOM generators [GL13]. However, there are specific challenges related to the generation of AIBOMs. One is **capturing dynamic aspects** (4). While traditional systems remain static in their behavior once deployed, AI-enabled systems might behave differently as they process new data [FL10, FL11]. For example, an AI model could learn from such new data and make different predictions [FL10, FL11]. In general, AIBOMs must deal with the co-evolution of data, models, code, and configurations [FL10]. Another challenge in AIBOM generation concerns the **available data** (3) used

Just Accepted

to generate AIBOMs. Data sources and repositories (*e.g.,* Hugging Face) often provide data that vary widely in both content and structure [FL12][GL13]. When such data is not adequately structured, it must be parsed from unstructured text, an approach that makes the generation process difficult and can reduce the reliability of the extracted information [GL13]. In other words, a lack of standardization and the use of multiple sources can lead to **accuracy** (3) concerns when generating AIBOMs like false positives and false negatives [GL15].

4.7.2 Consumption. A key challenge in consuming AIBOMs involves concerns around **intellectual property** (4). Developers may hesitate to adopt or fully populate AIBOMs due to fears of exposing information or losing intellectual property [FL8][GL15, GL23]. For instance, experts could reverse-engineer data from AIBOMs to compromise the vendor's intellectual property [GL26]. However, AIBOMs do not need to be public as they can be kept internal and shared selectively with verified stakeholders as needed [GL15]. Another possible challenge in AIBOM consumption relates to **security auditing** (2). The latter is fundamentally different for AI components compared to traditional software components, such as libraries [GL13]. Effective auditing would require a security database (similar to MITRE's CVE) tailored to AI-specific components [GL39]. Existing databases of AI vulnerabilities are inadequate for AIBOMs, as they often lack rigorous definitions and function more as general collections of security and ethics incidents [GL39]. This new security database should define clear abstractions of AI vulnerabilities and enforce a machine-readable format, enabling such a database to serve as a reliable data source for AIBOM-based security audits [GL39].

4.7.3 Interoperability. AIBOMs represent a specialized type of BOM designed to describe the AI components of the software supply chain; consequently, challenges may arise around **interoperability with other BOMs** (4). Different types of software require distinct information to be adequately described [FL8]. For instance, AIBOMs might not encompass specialized hardware components, such as graphics processing units (GPUs), necessitating complementary documentation like Hardware Bills of Materials (HBOM) [GL39]. Furthermore, with the emergence of quantum machine learning, future AIBOMs may need to incorporate quantum computing resources and algorithms as this technology matures and gains traction in AI applications[GL18]. The distinction between AIBOMs and other BOMs extends beyond including additional fields: It also reflects the unique nature of the information they represent [FL11]. AIBOMs also face challenges related to **interoperability with existing infrastructure** (3). This encompasses integration with established AIOps pipelines across various stages, including data collection, data transformation, model creation, model configuration, and model transformation [FL8][GL39].

4.7.4 Human aspects. Human-related challenges of AIBOMs are primarily associated with **education** (3). As AI remains an emerging technology, many in the industry lack a clear understanding of the purpose and requirements of AIBOMs, highlighting the need for targeted education and awareness [GL23, GL30]. Even with the availability of mature, automated AIBOM tools, effective integration into AIOps pipelines would require training IT operations and cybersecurity personnel to use them appropriately [GL39]. Another possible human-related challenge involves **information visualization** (2). While visual representations such as tables and graphs can effectively convey insights (*e.g.,* model performance or audit results), they are difficult to express in machine-readable formats like JSON [GL13]. Thus, providing a usable interface alongside structured data could significantly improve stakeholder engagement in AIBOMs [FL1].

4.7.5 Traceability. A key limitation of AIBOMs would be tracing **predictions** (2), particularly when attempting to attribute specific outputs to models within complex downstream components [GL39]. Despite this challenge, AIBOMs can support inspection and validation by enabling verifiable claims about contributions within the system [FL1]. Another possible challenge concerns tracking the **provenance** (1) of AI components throughout the supply chain. This includes model lineage, *i.e.,* the entire lineage from the current model to the foundational model to the data [GL13]. For example, the GPT4All-13B-Snoozy-SuperHOT-8K-GPTQ model is derived from Meta's 13B Llama, fine-tuned with GPT4All's Snoozy dataset using Low Rank Adaptation (LoRA), enhanced with SuperHot

Just Accepted

adapters for improved context reading, and then quantized for efficient storage and inference [GL13]. Provenance tracking is further complicated by inconsistent naming conventions [GL13]. The absence of standardized, unique identifiers remains a longstanding issue in traditional software and extends to AI components because it hinders the identification of components affected by a given issue [GL13].

4.7.6 Answering RQ6. Drawing on the findings obtained, we present our answer to RQ6 in the box below.

Despite the market opportunity, challenges and limitations related to *generation* primarily stem from the lack of mature AIBOM **generators**. Key issues include the difficulty of **capturing the dynamic aspects** of AI-enabled systems (*e.g.,* evolution of models) and having **available data**. Even when available, data could be unstructured or inconsistent across various sources. *Consumption* challenges and limitations involve **intellectual property** concerns (*e.g.,* disclosing sensitive information). *Interoperability* presents challenges and limitations both in aligning AIBOMs **with other BOMs** (*e.g.,* HBOM) and **with other existing infrastructure** (whose integrating might add further complexity). Challenges and limitations related to *human aspects* include the need for better **education** around AIBOM.

Notes: Both GL and FL consistently support similar findings. Notably, some claims are reported across both types of sources, including those about the lack of mature generators and available data, as well as challenges related to intellectual property or interoperability with existing infrastructure.

5 Discussion

A prominent theme across both FL and GL is the consensus on AIBOMs as a critical mechanism for documenting AI supply chain components—ranging from models and datasets to training procedures and associated risks. The transparency offered by AIBOMs is the most frequently acknowledged benefit and motivation for their use, underscoring their critical importance in the context of AI-enabled systems. As AI become increasingly ubiquitous, ensuring transparency is essential not only for traditional software components but also for the more intricate AI components that often underpin modern systems. Unlike conventional software, AI systems are inherently more complex and opaque, which poses significant challenges in understanding their behavior and dependencies. AIBOMs aim at addressing this complexity by providing a comprehensive inventory of all components involved in the creation and deployment of AI-enabled systems. The inventory of components described by AIBOMs is more extensive than what is typically expected by traditional SBOMs. While traditional SBOMs focus on components such as software libraries and packages, AIBOMs also include AI-specific components such as models, their underlying architectures, and detailed information about training and testing methodologies (*e.g.,* hyperparameters, performance, environmental impact). AIBOMs also include specifics about the training and test datasets (*e.g.,* collection, processing, ethical and privacy considerations). These additions enable AIBOMs to capture not just what the software system is made of, but how the AI behavior is shaped—whereas SBOMs are primarily aimed at representing the static composition of software systems, without accounting for influence in the system behavior through data or learning processes. AIBOMs' comprehensive inventory of components ensures transparency in the development and deployment of AI systems, promoting adherence to trustworthy AI principles such as fairness, accountability, and explainability, which is essential for fostering public trust in AI deployments.

The MLR also revealed that AIBOMs are not merely conceptual artifacts but are increasingly supported by concrete use cases, particularly in high-stakes domains such as healthcare, defense, and critical infrastructure. Furthermore, the alignment of AIBOMs with emerging regulations (*e.g.,* EU AI Act, US Executive Orders, ISO/IEC 42001) underscores their regulatory utility. For example, AIBOMs help address accountability in AI-enabled systems, where responsibility is often diffused across multiple stakeholders in the AI supply chain (*e.g.,* data scientists, model trainers, infrastructure providers). By providing a structured and traceable record of data, models,

Just Accepted

and decisions—including AI-specific concerns like data lineage, model provenance, and ethical or environmental considerations—AIBOMs enable clearer attribution of responsibility, particularly in cases where systems cause harm or make erroneous decisions.

However, while motivations and benefits are well-articulated, practical adoption is hindered by substantial challenges. Chief among these is the insufficient and fragmented automation support for AIBOMs generation and consumption. Despite growing interest in AIBOMs, our MLR reveals a significant lack of mature, publicly accessible tools. Currently, only one proprietary tool claims to support AIBOM generation; however, we were unable to verify its functionality. Overall, AIBOM generation remains largely manual, fragmented, and prone to errors, which limits its scalability in practice. On the consumption side, there are no dedicated tools to support key use cases such as AI component management, compliance verification, or security assessment, which further hinders practical AIBOM adoption. Compounding these challenges is the lack of adequate underlying data needed to generate AIBOMs in the first place. While information sources like model cards and data sheets are discussed as starting points, they are not yet widely adopted or integrated into AI development life-cycles. For example, these information sources only offer partial support for AIBOM generation and lack both machine-readability and standardization, which hinders the extraction and synthesis of relevant data to include in AIBOMs.

Another important insight is the socio-technical nature of AIBOMs. Beyond technical traceability and security, they are positioned as enablers of ethical AI practices and responsible innovation. This multidimensionality introduces both opportunities and tensions. For example, the same documentation needed for reproducibility can raise concerns about intellectual property or national security.

While the obtained results carry important implications for several stakeholders, we present below those related to the primary target audience of our MLR, namely practitioners and researchers. We conclude this section by discussing the threats that could affect the validity of the findings of our MLR.

5.1 Implications and Future Work

The MLR results suggest implications relevant to **researchers**, highlighting both existing gaps and emerging opportunities that warrant further investigation and focused effort. These implications can be summarized as follows:

- **AIBOMs Evaluation Evidence (RQ1, RQ4)**: There is no current evidence on the effectiveness of AIBOMs in real-world development. Empirical studies should examine whether and how AIBOMs improve trust, traceability, or compliance in practice. Comparative studies across domains (*e.g.,* healthcare and defense) could yield insights into domain-specific requirements and barriers.
- **Intersections with AI Ethics and Accountability (RQ1, RQ2, RQ3, RQ4)**: AIBOMs have the potential to operationalize AI principles like fairness, privacy violations, racial bias, transparency, and responsibility. Further studies should investigate how AIBOMs can support algorithmic accountability through design-time and run-time documentation, and whether they can act as 'transparency artifacts" for stakeholders.
- **Tooling for Automated AIBOM Generation (RQ5, RQ6):** The lack of automation emerged as a critical challenge, revealing a gap in the availability of tools to generate AIBOMs. This points to an important opportunity for researchers to develop methods and tools capable of automatically extracting relevant metadata from AI development artifacts and software repositories (*e.g.,* AI pipelines, model training logs, dataset lineage systems, and code repositories). Future research could also explore techniques in software instrumentation, provenance tracking, and static/dynamic analysis for AI artifacts. Additionally, existing resources like model cards (*e.g.,* Hugging Face model cards) and datasheets were found to offer only partial coverage, often lacking both machine readability and standardization. Researchers should explore how these information sources can be evolved or integrated into the AIBOMs.

Just Accepted

- **Defining Minimum Viable AIBOMs (RQ3):** Researchers should focus on developing and validating tiered frameworks that define minimum viable AIBOMs tailored to varying levels of AI risks, data sensitivity, and deployment contexts. They should also assess how these frameworks can be practically implemented across diverse industries and organizational sizes. Furthermore, exploring how such tiered approaches can be integrated with existing regulatory requirements and technical standards will be key to promoting their widespread adoption and effectiveness.
- **Replication and Expansion of the Review (RQ1, RQ2, RQ3, RQ4, RQ5, RQ6)**: A promising direction for future work would be to replicate and extend this systematic review with a dedicated focus only on FL. While the current body of peer-reviewed research on AIBOMs remains limited and insufficient to justify an SLR, it is expanding rapidly. As this corpus matures, a follow-up SLR centered exclusively on FL will become both feasible and necessary to consolidate emerging evidence and refine the conceptual foundations established in our study. Our documented search string and publicly available replication package [74] provide a transparent and reproducible basis for such an endeavor, enabling researchers to build directly on our methodology, which, we recall, is based on the well-known and established guidelines by Garousi *et al.* [57] and Kitchenham and Charters [68]. Replications and extensions of our systematic review would also allow capturing developments and trends that were either absent or only incipient at the time of our original study.

AIBOMs offer immediate and long-term opportunities for engineering and operational teams. Bearing this in mind, we outline the following implications of our results that are relevant to **practitioners**:

- **Risk Management and Security-by-Design (RQ1, RQ4, RQ6)**: Practitioners can adopt AIBOMs to proactively identify and mitigate vulnerabilities, dataset contamination, and licensing risks. Integrating AIBOMs into the development pipelines could enhance resilience and reduce incident response time, especially in regulated sectors.
- **Operationalization of Responsible AI Practices (RQ1, RQ3)**: AIBOMs can serve to document ethical trade-offs, model limitations, and sustainability metrics. Organizations seeking to align with emerging standards (*e.g.,* NIST AI Risk Management Framework, ISO/IEC 42001) may use AIBOMs as a means that supports internal audits and external disclosures.
- **Enhancing Accountability in the AI Supply Chain (RQ1, RQ2, RQ3, RQ4)**: Practitioners developing or deploying AI-enabled systems should adopt AIBOMs to ensure clear accountability across the AI supply chain, enabling traceability and responsibility attribution in the event of failures, harm, or ethical concerns.
- **Adoption of Interoperable Standards (RQ2, RQ5)**: Although CycloneDX and SPDX are the most referenced, their current support for AI artifacts is limited. Practitioners are advised to participate in open standardization efforts for AIBOMs or adopt existing information sources (*e.g.,* model cards) as a starting point while anticipating future extensions.
- **Model and Dataset Lifecycle Management (RQ4)**: We observed that AIBOMs facilitate component traceability, rollback, and model re-training in the development pipelines of complex AI-enabled systems. Practitioners should begin incorporating AIBOMs during the early stages of development and possibly integrate them with existing tools (*e.g.,* MLFlow, DVC, or Kubernetes-based AI workflows).
- **Tool Development Opportunity (RQ5, RQ6)**: The primary limitation lies in the lack of mature AIBOM generators. To date, only one source claims to provide an AIBOM, though this may be promotional in nature, as we were unable to retrieve or verify the tool's functionality or compliance with declared standards. This highlights a clear gap and signals a strong opportunity for innovation in developing user-friendly, automated AIBOM generators. Such tooling could serve as a differentiator for AI vendors aiming to deliver compliance-ready. Tooling limitations also extend to the consumption of AIBOMs. As

Just Accepted

AIBOM adoption grows, there will be as well opportunity to develop dedicated AIBOM consumption tools that support the analysis and operational use of AIBOMs—such as auditing for ethical violations or verifying license compliance.

- **Navigating International Regulatory Variations (RQ2, RQ6)**: Practitioners should proactively monitor and understand the evolving landscape of AI transparency regulations across different regions, such as the EU, US, and China, recognizing that each country may impose unique requirements and considerations for deploying AI-enabled software. Adopting AIBOMs can help manage these differences and ultimately reduce the risks of fragmented compliance obligations across jurisdictions.

5.2 Threats to Validity

In this section, we discuss the threats that might affect the validity of our study based on the classification provided by Wohlin *et al.* [95].

5.2.1 Construct Validity. They are concerned with the relation between theory and observation [95]. In our MLR, potential threats to construct validity were primarily related to the formulation of the RQs and the design of the data extraction. To mitigate these threats, we followed the GQM methodology [44], as recommended by Garousi *et al.* [57], to ensure the alignment and traceability of the study's objectives, RQs, and the data extraction form. Each author independently reviewed the RQs and data extraction form, and discrepancies were resolved through collaborative discussions. In MLRs, such threats often arise from inaccurate data extraction, incomplete coverage of relevant studies due to limitations in search string, the use of search engines, and potential researcher bias in applying inclusion, exclusion, or quality criteria (*e.g.,* [54, 58, 59]). In constructing our search string, we included both the most common words (*e.g.,* AIBOM) but also similar terms used by different authors for pointing to a similar concept (*e.g.,* DataBOM). As for the choice of search engines, we chose Scopus, IEEE Xplore, and the ACM Digital Library for the FL—which are considered among the top computer science data sources [79] and are recommended by the guidelines [57, 68]—and Google Search Engine for the GL—which is recommended by the guidelines for including GL in systematic reviews [43, 57]. To further reduce the risk of missing relevant FL and GL sources, we employed backward and forward snowballing following the related guidelines [57, 94]. Another construct validity threat might arise from the lack of empirical rigor in the information based on practitioner experience or subjective opinion. While this aligns with the broader aims of MLRs, which intentionally integrate both FL and GL, we acknowledge potential biases introduced by the heavy reliance on GL sources. These may include the risk of overstating benefits, presenting overly optimistic claims without empirical support, promotional- and marketing-driven content, and a lack of negative views on AIBOMs. Although we followed the guidelines by Garousi *et al.* [57]—which include quality assessment criteria targeting subjectivity and vested interests—some bias may persist despite these mitigation efforts. Indeed, we found no sources that explicitly presented negative views on AIBOMs, such as dissenting or critical perspectives regarding their feasibility.

5.2.2 Reliability Validity. They are concerned with the extent to which the data and the analysis are dependent on the specific researchers [95]. Potential threats to reliability validity regarded the application of inclusion, exclusion, and quality criteria. These were mitigated by having two individuals independently apply the criteria across all sources. To evaluate the inter-rater (*i.e.,* authors) agreement, we calculated the Cohen's κ coefficient. We obtained an almost perfect agreement. In detail, Cohen's κ was 0.82 for the selection of FL, 0.89 for GL, and 0.87 overall. These values indicate strong consistency between raters and support the reliability of our source selection process. In case of disagreement, the final decision on including a given source was made through a discussion between the two authors. If consensus could not be reached, the plan was to involve the remaining authors. However, this was not necessary, as all disagreements were successfully resolved between the two authors who applied the inclusion, exclusion, and quality criteria. Finally, while data extraction was performed

Just Accepted

independently and in parallel by two authors, we acknowledge that having data synthesis conducted by a single author may introduce a risk of subjective interpretation.

5.2.3 External Validity. They are concerned with the generalizability of results [95]. We conducted our MLR on the most popular and recommended data sources for both FL [57, 68, 79] and GL [43, 57]. Additionally, we conducted snowballing following the related guidelines [57, 94] to identify further relevant studies. Nevertheless, we cannot claim to have examined all the possible FL and GL sources. For example, some potentially relevant sources may not have been properly indexed or may not be freely available. Another potential threat to generalizability stems from the inclusion and exclusion criteria. For example, we included only sources written in English; thus, studies written in other languages were excluded. In this respect, we argue that the final set of included sources contained a sufficiently comprehensive and diverse representation of both academic and practitioner perspectives. Finally, we acknowledge that findings based on very few sources (*e.g.,* explainability for RQ1) may have limited generalizability beyond the specific contexts in which they were reported (*e.g.,* they may reflect isolated perspectives, early-stage developments, or context-specific practices rather than broadly established trends). These findings should be interpreted with caution, as they highlight underrepresented aspects that may require further exploration.

6 Conclusion

This paper presented a Multivocal Literature Review (MLR) synthesizing insights from formal and gray literature (FL and GL, respectively) to provide an understanding of AIBOMs (Artificial Intelligence Bills of Materials). Our study is the first comprehensive synthesis that integrates both FL and GL on AIBOMs and consolidates, contextualizes, and critically analyzes the scattered and heterogeneous body of knowledge currently available on this topic. We recognize that AIBOMs are relatively recent and that while they are gaining traction, further research and industry collaboration are necessary to ensure their widespread adoption and effectiveness in managing the AI supply chain. Future research should focus on developing standardized frameworks, assessing real-world applications, and exploring automated solutions for the AI supply chain with AIBOM. Additionally, continued engagement between academia and industry practitioners will be crucial in effectively supporting the AIBOM adoption.

While some of the conceptual benefits and usages of AIBOMs may appear self-evident, we require empirical grounding and explicit discussion in a systematic review to remain essential to establish a solid foundation for future research and to prevent assumptions from becoming unexamined truths. For example, the results of our MLR can serve as a foundation for further research on the role of AIBOM in AI supply chain security, compliance, and responsible AI deployment.

Data Availability

We made available online the data of our MLR [74]. It includes information about the selection process for FL and GL, covering the application of inclusion, exclusion, and quality criteria; the data extracted from each source during data extraction; and the results of the qualitative analysis conducted as part of the data synthesis.

Acknowledgments

This research has been financially supported by the European Union NEXTGenerationEU project and by the Italian Ministry of the University and Research MUR, a Research Project of Significant National Interest (PRIN) 2022 PNRR, project n. D53D23017310001 entitled ‘Mining Software Repositories for enhanced Software Bills of Materials (MSR4SBOM)’.

Just Accepted

MLR—Formal Literature

[FL1] Iain Barclay, Alun Preece, Ian Taylor, Swapna Krishnakumar Radha, and Jarek Nabrzyski. 2023. Providing assurance and scrutability on shared data and machine learning models with verifiable credentials. *Concurrency and Computation: Practice and Experience* 35, 18 (2023), e6997. 10.1002/cpe.6997 Journal Article.

[FL2] Tingting Bi, Boming Xia, Zhenchang Xing, Qinghua Lu, and Liming Zhu. 2024. On the Way to SBOMs: Investigating Design Issues and Solutions in Practice. *ACM Transactions on Software Engineering and Methodology* 33, 6 (2024), 1–25. 10.1145/3654442 Journal Article.

[FL3] Ian Taylor Iain Barclay, Alun Preece. 2019. Towards traceability in data ecosystems using a bill of materials model. In *International Workshop on Science Gateways*. CEUR-WS. https://ceur-ws.org/Vol-2975/paper3.pdf Workshop Paper.

[FL4] Yue Liu, Dawen Zhang, Boming Xia, Julia Anticev, Tunde Adebayo, Zhenchang Xing, and Moses Machao. 2024. Blockchain-Enabled Accountability in Data Supply Chain: A Data Bill of Materials Approach. In *IEEE International Conference on Blockchain*. IEEE, 557–562. https://doi.org/10.1109/Blockchain62396.2024.00082 Conference Paper.

[FL5] Qinghua Lu, Liming Zhu, Xiwei Xu, Yue Liu, Zhenchang Xing, and Jon Whittle. 2024. A Taxonomy of Foundation Model based Systems through the Lens of Software Architecture. In *IEEE/ACM International Conference on AI Engineering-Software Engineering for AI*. ACM, 1–6. https://doi.org/10.1145/3644815.3644956 Conference Paper.

[FL6] Federica Pepe, Vittoria Nardone, Antonio Mastropaolo, Gabriele Bavota, Gerardo Canfora, and Massimiliano Di Penta. 2024. How do Hugging Face Models Document Datasets, Bias, and Licenses? An Empirical Study. In *IEEE/ACM International Conference on Program Comprehension*. ACM, 370–381. https://doi.org/10.1145/3643916.3644412 Conference Paper.

[FL7] Petar Radanliev, Omar Santos, and Alistair Brandon-Jones. 2024. Capability hardware enhanced instructions and artificial intelligence bill of materials in trustworthy artificial intelligence systems: analyzing cybersecurity threats, exploits, and vulnerabilities in new software bills of materials with artificial intelligence. *The Journal of Defense Modeling and Simulation* (2024), 15485129241267919. 10.1177/15485129241267919 Journal Article.

[FL8] Trevor Stalnaker, Nathan Wintersgill, Oscar Chaparro, Massimiliano Di Penta, Daniel M German, and Denys Poshyvanyk. 2024. BOMs Away! Inside the Minds of Stakeholders: A Comprehensive Study of Bills of Materials for Software Systems. In *IEEE/ACM International Conference on Software Engineering*. ACM, 1–13. https://doi.org/10.1145/3597503.3623347 Conference Paper.

[FL9] Shenao Wang, Yanjie Zhao, Xinyi Hou, and Haoyu Wang. 2024. Large Language Model Supply Chain: A Research Agenda. *ACM Transactions on Software Engineering and Methodology* (2024). 10.1145/3708531 Journal Article.

[FL10] Boming Xia, Tingting Bi, Zhenchang Xing, Qinghua Lu, and Liming Zhu. 2023. An Empirical Study on Software Bill of Materials: Where We Stand and the Road Ahead. In *IEEE/ACM International Conference on Software Engineering*. IEEE, 2630–2642. https://doi.org/10.1109/ICSE48619.2023.00219 Conference Paper.

[FL11] Boming Xia, Dawen Zhang, Yue Liu, Qinghua Lu, Zhenchang Xing, and Liming Zhu. 2024. Trust in Software Supply Chains: Blockchain-Enabled SBOM and the AIBOM Future. In *IEEE/ACM International Workshop on Engineering and Cybersecurity of Critical Systems & IEEE/ACM International Workshop on Software Vulnerability*. ACM, 12–19. https://doi.org/10.1145/3643662.3643957 Workshop Paper.

[FL12] Dawen Zhang, Boming Xia, Yue Liu, Xiwei Xu, Thong Hoang, Zhenchang Xing, Mark Staples, Qinghua Lu, and Liming Zhu. 2024. Privacy and Copyright Protection in Generative AI: A Lifecycle Perspective. In *IEEE/ACM International Conference on AI Engineering-Software Engineering for AI*. ACM, 92–97. https://doi.org/10.1145/3644815.3644952 Conference Paper.

MLR—Gray Literature

[GL13] Daniel Bardenstein, Nitish Kulkarni, Jakob Frick, Marc Frankel, Tiff Hsieh, and Amy Villasenor. 2023. *Driving AI Transparency: the AI Bill of Materials*. https://manifest-public-shareable-resources.s3.us-east-1.amazonaws.com/Manifest%2BAIBOM%2BWhitepaper.pdf White paper.

[GL14] Karen Bennet, Gopi Krishnan Rajbahadur, Arthit Suriyawongkul, and Kate Stewart. 2024. *Implementing AI Bill of Materials (AI BOM) with SPDX 3.0 - A Comprehensive Guide to Creating AI and Dataset Bill of Materials*. https://www.linuxfoundation.org/hubfs/LF%20Research/lfr_spdx_aibom_102524a.pdf White paper.

[GL15] Faith Kimberley Coslett. 2024. *Intern Poster AIBOMs in Automated Defense: Capabilities & Challenges*. https://inldigitallibrary.inl.gov/sites/STI/STI/Sort_123578.pdf Poster.

[GL16] Bill Doerrfeld. 2023. *Leading SBOM Standard CycloneDX Now Incorporates Machine Learning*. https://cloudwars.com/cybersecurity/leading-sbom-standard-cyclonedx-now-incorporates-machine-learning/ News Article.

[GL17] Gorkem Ercan. 2024. *Unifying Documentation and Provenance for AI and ML: A Developer's Guide to Navigating the Chaos*. https://dev.to/kitops/unifying-documentation-and-provenance-for-ai-and-ml-a-developers-guide-to-navigating-the-chaos-1n1o Blogs.

[GL18] Bijit Ghosh. 2024. *AI Bill of Materials (AI BOM)*. https://medium.com/@bijit211987/ai-bill-of-materials-ai-bom-80d48f9d75e0 Blogs.

[GL19] James Governor. 2023. *Introducing the AI Bill of Materials*. https://redmonk.com/jgovernor/2023/10/18/introducing-the-ai-bill-of-materials/ Blogs.

Just Accepted

[GL20] Sydney J. Freedberg Jr. 2024. *'AI-BOM' bombs: Army backs off, will demand less detailed data from AI vendors.* https://breakingdefense.com/2024/04/ai-bom-bombs-army-backs-off-will-demand-less-detailed-data-from-ai-vendors/ News Article.
[GL21] Diana Kelley. 2024. *Why MLBOMs Are Useful for Securing the AI/ML Supply Chain.* https://www.darkreading.com/vulnerabilities-threats/mlboms-are-useful-for-securing-ai-ml-supply-chain News Article.
[GL22] James Lee. 2024. *Model-Based Systems Engineering(MBSE) Approach to Develop an ArtificialIntelligence Bill of Material (AIBOM) forAI System Compliance Verification.* https://sercuarc.org/wp-content/uploads/2024/09/Slides-Model-Based-Systems-Engineering-MBSE-Approach-to-Develop-an-Artificial-Intelligence-Bill-of-Material-AIBOM-for-AI-System-Compliance-Verification.pdf Presentation.
[GL23] Liqian Lim. 2024. *The Essential Guide to AI Bills of Materials (AIBOMs).* https://snyk.io/articles/ai-security/ai-bill-of-materials-aibom/ Blogs.
[GL24] David Mor-Ofek. 2024. *It's Time to Talk About AI/ML BOM (Artificial Intelligence Bill of Materials) And Vulnerability Management.* https://c2a-sec.com/its-time-to-talk-about-ai-ml-bom-artificial-intelligence-bill-of-materials-and-vulnerability-management/ Blogs.
[GL25] nan. 2024. *Bringing in the BoM Squad: Defining and Generating AI Bill of Materials - Securin.* https://www.securin.io/articles/bringing-in-the-bom-squad-defining-and-generating-ai-bill-of-materials/ Blogs.
[GL26] nan. 2024. *Public and/or Shared AI Models Cannot be Trusted Until an AI Bill of Materials Become the Norm.* https://www.pivotpointsecurity.com/public-and-or-shared-ai-models-cannot-be-trusted-until-an-ai-bill-of-materials-become-the-norm/ Blogs.
[GL27] nan. 2025. *AI - SPDX.* https://spdx.dev/learn/areas-of-interest/ai/ Blogs.
[GL28] nan. 2025. *CycloneDX v1,6 JSON Reference.* https://cyclonedx.org/docs/ Documentation.
[GL29] nan. 2025. *Machine Learning Bill of Materials (ML-BOM) | CycloneDX.* https://cyclonedx.org/capabilities/mlbom/ Blogs.
[GL30] Danny Nebenzahl. 2023. *ML-What? Understanding the ML-Bom Concept and Uses.* https://scribesecurity.com/blog/ml-sbom/ Blogs.
[GL31] Helen Oakley. 2024. *Building a Stronger Software Supply Chain with SBOM and AIBOM: Insights from Recent Industry Events.* https://www.linkedin.com/pulse/building-stronger-software-supply-chain-sbom-aibom-insights-oakley-g6p4c Social Media Post.
[GL32] Helen Oakley. 2024. *Securing AI Ecosystems: The Critical Role of AIBOM in Mitigating Software Supply Chain Risks.* https://csrc.nist.gov/csrc/media/Presentations/2024/securing-ai-ecosystems-the-critical-role-of-aibom/images-media/20240917_Securing%20AI%20Ecosystems.pdf Presentation.
[GL33] Omar Santos. 2023. *Artificial Intelligence Bill-of-Materials (AI BOMs): Ensuring AI Transparency and Traceability.* https://becomingahacker.org/artificial-intelligence-bill-of-materials-ai-boms-ensuring-ai-transparency-and-traceability-82322643bd2a Blogs.
[GL34] Omar Santos. 2024. *Understanding the SPDX 3.0 AI BOM Support.* https://becomingahacker.org/understanding-the-spdx-3-0-ai-bom-support-7f3dbdd28345 Blogs.
[GL35] Meixue Si, Shidong Pan, Dianshu Liao, Xiaoyu Sun, Zhen Tao, Wenchang Shi, and Zhenchang Xing. 2024. *A Solution toward Transparent and Practical AI Regulation: Privacy Nutrition Labels for Open-source Generative AI-based Applications.* https://arxiv.org/abs/2407.15407 Pre-print.
[GL36] Trevor Stalnaker, Nathan Wintersgill, Oscar Chaparro, Laura A Heymann, Massimiliano Di Penta, Daniel M German, and Denys Poshyvanyk. 2025. *The ML Supply Chain in the Era of Software 2.0: Lessons Learned from Hugging Face.* https://arxiv.org/abs/2502.04484 Pre-print.
[GL37] Sema Team. 2023. *Generative AI Bill of Materials (GBOM): A Primer | Sema.* https://www.semasoftware.com/blog/generative-ai-bill-of-materials-gbom-tm-a-primer Blogs.
[GL38] Wiz Experts Team. 2025. *AI-BOM: Building an AI-Bill of Materials.* https://www.wiz.io/academy/ai-bom-ai-bill-of-materials Blogs.
[GL39] Adelin Travers, Michael Brown, and Heidy Khlaaf. 2024. *Our response to the US Army's RFI on developing AIBOM tools | Trail of Bits Blog.* https://www.trailofbits.com/documents/PEO_AIBOM_RFI_Response.pdf Blogs.
[GL40] Kimberly Underwood. 2023. *U.S. Army Is Considering AI Bill of Materials | AFCEA International.* https://www.afcea.org/signal-media/cyber-edge/us-army-considering-ai-bill-materials News Article.

References

[41] ACM. 2025. *ACM Digital Library.* https://dl.acm.org/
[42] Jean Adams, Frances C Hillier-Brown, Helen J Moore, Amelia A Lake, Vera Araujo-Soares, Martin White, and Carolyn Summerbell. 2016. Searching and synthesising 'grey literature'and 'grey information'in public health: critical reflections on three case studies. *Systematic reviews* 5 (2016), 1–11.
[43] Richard J Adams, Palie Smart, and Anne Sigismund Huff. 2017. Shades of grey: guidelines for working with the grey literature in systematic reviews for management and organizational studies. *International journal of management reviews* 19, 4 (2017), 432–454.
[44] Victor R Basili. 1992. *Software modeling and measurement: the Goal/Question/Metric paradigm.* University of Maryland at College Park.
[45] Daniel Bendler and Michael Felderer. 2023. Competency models for information security and cybersecurity professionals: analysis of existing work and a new model. *ACM Transactions on Computing Education* 23, 2 (2023), 1–33.

Just Accepted

[46] Lionel Briand, Domenico Bianculli, Shiva Nejati, Fabrizio Pastore, and Mehrdad Sabetzadeh. 2017. The case for context-driven software engineering research: generalizability is overrated. *IEEE Software* 34, 5 (2017), 72–75.
[47] Torgeir Dingsøyr, Finn Olav Bjørnson, and Forrest Shull. 2009. What do we know about knowledge management? Practical implications for software engineering. *IEEE software* 26, 3 (2009), 100–103.
[48] Tore Dyba and Torgeir Dingsoyr. 2009. What do we know about agile software development? *IEEE software* 26, 5 (2009), 6–9.
[49] Tore Dybå, Dag IK Sjøberg, and Daniela S Cruzes. 2012. What works for whom, where, when, and why? On the role of context in empirical software engineering. In *Proceedings of the ACM-IEEE international symposium on Empirical software engineering and measurement*. 19–28.
[50] Steve Easterbrook, Janice Singer, Margaret-Anne Storey, and Daniela Damian. 2008. Selecting empirical methods for software engineering research. *Guide to advanced empirical software engineering* (2008), 285–311.
[51] European Union. 2024. *EU AI Act - Regulation - EU - 2024/1689 - EN - EUR-Lex*. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689/
[52] European Union Agency for Cybersecurity. 2020. *Guidelines for Securing the Internet of Things - ENISA*. https://www.enisa.europa.eu/publications/guidelines-for-securing-the-internet-of-things
[53] Vahid Garousi and Michael Felderer. 2017. Worlds apart: industrial and academic focus areas in software testing. *IEEE software* 34, 5 (2017), 38–45.
[54] Vahid Garousi, Michael Felderer, and Tuna Hacaloğlu. 2017. Software test maturity assessment and test process improvement: A multivocal literature review. *Information and Software Technology* 85 (2017), 16–42.
[55] Vahid Garousi, Michael Felderer, and Tuna Hacaloğlu. 2017. What we know about software test maturity and test process improvement. *Ieee Software* 35, 1 (2017), 84–92.
[56] Vahid Garousi, Michael Felderer, Çağrı Murat Karapıçak, and Uğur Yılmaz. 2018. What we know about testing embedded software. *IEEE Software* 35, 4 (2018), 62–69.
[57] Vahid Garousi, Michael Felderer, and Mika V Mäntylä. 2019. Guidelines for including grey literature and conducting multivocal literature reviews in software engineering. *Information and software technology* 106 (2019), 101–121.
[58] Vahid Garousi and Barış Küçük. 2018. Smells in software test code: A survey of knowledge in industry and academia. *Journal of systems and software* 138 (2018), 52–81.
[59] Vahid Garousi and Mika V Mäntylä. 2016. When and what to automate in software testing? A multi-vocal literature review. *Information and Software Technology* 76 (2016), 92–117.
[60] Carmine Giardino, Michael Unterkalmsteiner, Nicolo Paternoster, Tony Gorschek, and Pekka Abrahamsson. 2014. What do we know about software development in startups? *IEEE software* 31, 5 (2014), 28–32.
[61] Google. 2025. *Google*. https://www.google.com/
[62] Neal Robert Haddaway, Alexandra Mary Collins, Deborah Coughlin, and Stuart Kirk. 2015. The Role of Google Scholar in Evidence Reviews and Its Applicability to Grey Literature Searching. *PLOS ONE* 10 (09 2015), 1–17. https://doi.org/10.1371/journal.pone.0138237
[63] Tracy Hall, Helen Sharp, Sarah Beecham, Nathan Baddoo, and Hugh Robinson. 2008. What do we know about developer motivation? *IEEE software* 25, 4 (2008), 92–94.
[64] Kaifeng Huang, Bihuan Chen, You Lu, Susheng Wu, Dingji Wang, Yiheng Huang, Haowen Jiang, Zhuotong Zhou, Junming Cao, and Xin Peng. 2025. Lifting the Veil on Composition, Risks, and Mitigations of the Large Language Model Supply Chain. arXiv:2410.21218 [cs.SE] https://arxiv.org/abs/2410.21218
[65] IEEE. 2025. *IEEE Xplore*. https://ieeexplore.ieee.org/Xplore/home.jsp/
[66] Chadni Islam, Muhammad Ali Babar, and Surya Nepal. 2019. A multi-vocal review of security orchestration. *ACM Computing Surveys (CSUR)* 52, 2 (2019), 1–45.
[67] Barbara Kitchenham, O Pearl Brereton, David Budgen, Mark Turner, John Bailey, and Stephen Linkman. 2009. Systematic literature reviews in software engineering–a systematic literature review. *Information and software technology* 51, 1 (2009), 7–15.
[68] Barbara Kitchenham and Stuart Charters. 2007. Guidelines for performing systematic literature reviews in software engineering.
[69] Stefano Lambiase, Gemma Catolino, Fabio Palomba, and Filomena Ferrucci. 2024. Motivations, Challenges, Best Practices, and Benefits for Bots and Conversational Agents in Software Engineering: A Multivocal Literature Review. *Comput. Surveys* 57, 4 (2024), 1–37.
[70] Veronika Lesch, Marwin Züfle, André Bauer, Lukas Iffländer, Christian Krupitzer, and Samuel Kounev. 2023. A literature review of IoT and CPS—What they are, and what they are not. *Journal of Systems and Software* 200 (2023), 111631.
[71] Yuko McGrath, Mark Bellis, Keith Edmonds, Jim McVeigh, and Harry Sumnall. 2006. *Review of grey literature on drug prevention among young people*. National Institute for Health and Clinical Excellence London.
[72] Matthew B Miles and A Michael Huberman. 1994. *Qualitative data analysis: An expanded sourcebook*. sage.
[73] National Institute of Standards and Technology. 2023. *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. Technical Report NIST AI 100-1. U.S. Department of Commerce. https://doi.org/10.6028/NIST.AI.100-1 January 2023.
[74] Sabato Nocera, Massimiliano Di Penta, Fatima Ahmed, Simone Romano, and Giuseppe Scanniello. 2025. *What We Know about AIBOMs: Results from a Multivocal Literature Review on Artificial Intelligence Bill of Materials - Supplementary Materials*. https:

Just Accepted

//doi.org/10.6084/m9.figshare.29719163

[75] Sabato Nocera, Massimiliano Di Penta, Rita Francese, Simone Romano, and Giuseppe Scanniello. 2024. If it's not SBOM, then what? How Italian Practitioners Manage the Software Supply Chain. In *2024 IEEE International Conference on Software Maintenance and Evolution (ICSME)*. IEEE, 730–740. https://doi.org/10.1109/ICSME58944.2024.00077

[76] Sabato Nocera, Simone Romano, Massimiliano Di Penta, Rita Francese, and Giuseppe Scanniello. 2025. On the adoption of software bill of materials in open-source software projects. *Journal of Systems and Software* (2025), 112540. https://doi.org/10.1016/j.jss.2025.112540

[77] Rodney T Ogawa and Betty Malen. 1991. Towards rigor in reviews of multivocal literatures: Applying the exploratory case study method. *Review of educational research* 61, 3 (1991), 265–286.

[78] Ipek Ozkaya. 2020. What Is Really Different in Engineering AI-Enabled Systems? *IEEE Softw.* 37, 4 (2020), 3–6. https://doi.org/10.1109/MS.2020.2993662

[79] Paperpile. 2025. *The best research databases for computer science.* https://paperpile.com/g/research-databases-computer-science/

[80] Severi Peltonen, Luca Mezzalira, and Davide Taibi. 2021. Motivations, benefits, and issues for adopting micro-frontends: A multivocal literature review. *Information and Software Technology* 136 (2021), 106571.

[81] Kai Petersen and Claes Wohlin. 2009. Context in industrial software engineering research. In *2009 3rd international symposium on empirical software engineering and measurement*. IEEE, 401–404.

[82] Colin Potts. 1993. Software-engineering research revisited. *IEEE software* 10, 5 (1993), 19–28.

[83] Adib Bin Rashid and MD Ashfakul Karim Kausik. 2024. AI revolutionizing industries worldwide: A comprehensive overview of its diverse applications. *Hybrid Advances* 7 (2024), 100277.

[84] Scopus. 2025. *Scopus preview - Scopus - Welcome to Scopus.* https://www.scopus.com/home.uri/

[85] Forrest Shull, Grigori Melnik, Burak Turhan, Lucas Layman, Madeline Diep, and Hakan Erdogmus. 2010. What do we know about test-driven development? *IEEE software* 27, 6 (2010), 16–19.

[86] Anselm Strauss, Juliet Corbin, et al. 1990. *Basics of qualitative research*. Vol. 15. sage Newbury Park, CA.

[87] Amjed Tahir, Shawn Rasheed, Jens Dietrich, Negar Hashemi, and Lu Zhang. 2023. Test flakiness' causes, detection, impact and responses: A multivocal review. *Journal of Systems and Software* 206 (2023), 111837.

[88] The Linux Foundation. 2022. *The State of Software Bill of Materials (SBOM) and Cybersecurity Readiness.* https://www.linuxfoundation.org/research/the-state-of-software-bill-of-materials-sbom-and-cybersecurity-readiness/ Last Accessed: November 15, 2024.

[89] The White House. 2021. *Executive Order on Improving the Nation's Cybersecurity.* https://bidenwhitehouse.archives.gov/briefing-room/presidential-actions/2021/05/12/executive-order-on-improving-the-nations-cybersecurity/

[90] United States Department of Commerce. 2021. *The Minimum Elements For a Software Bill of Materials (SBOM).* https://www.ntia.doc.gov/files/ntia/publications/sbom_minimum_elements_report.pdf

[91] United States Government. 2021. *Executive Order on Improving the Nation's Cybersecurity | The White House.* https://bidenwhitehouse.archives.gov/briefing-room/presidential-actions/2025/01/16/executive-order-on-strengthening-and-promoting-innovation-in-the-nations-cybersecurity/

[92] Maike Vollstedt and Sebastian Rezat. 2019. An introduction to grounded theory with a special focus on axial coding and the coding paradigm. *Compendium for early career researchers in mathematics education* 13, 1 (2019), 81–100.

[93] David Gray Widder and Dawn Nafus. 2023. Dislocated accountabilities in the "AI supply chain": Modularity and developers' notions of responsibility. *Big Data & Society* 10, 1 (2023), 20539517231177620.

[94] Claes Wohlin. 2014. Guidelines for snowballing in systematic literature studies and a replication in software engineering. In *Proceedings of the 18th international conference on evaluation and assessment in software engineering*. 1–10.

[95] Claes Wohlin, Per Runeson, Martin Höst, Magnus C Ohlsson, Björn Regnell, Anders Wesslén, et al. 2012. *Experimentation in software engineering*. Vol. 236. Springer.

[96] Nusrat Zahan, Elizabeth Lin, Mahzabin Tamanna, William Enck, and Laurie Williams. 2023. Software Bills of Materials Are Required. Are We There Yet? *IEEE Security & Privacy* 21, 2 (2023), 82–88. https://doi.org/10.1109/MSEC.2023.3237100

Just Accepted